Threat Intelligence

Threat evolution in Q1 2020

April 2020

group-ib.com

Contents

INTRODUCTION **3**

EXECUTIVE SUMMARY **4**

Targeted attacks on the financial sector 4

Financial threats 4

Ransomware 5

Exploits 6

Threats to the government sector 6

Data leaks 8

FORECASTS FOR Q2 2020 **9**

ADVANCED THREATS IN THE FINANCIAL SECTOR **10**

FINANCIAL THREATS **16**

Malware for Android 17

Threats and malware for PC 18

Attacks on ATMs and POS terminals 27

RANSOMWARE **29**

EXPLOITS **31**

STATE-SPONSORED APTS **34**

DATA LEAKS **58**

Introduction

Every quarter Group-IB releases a report on the development of high tech cyber-crime, featuring new tendencies, emerging trends, and predictions on the cyber-threat landscape.

The most dangerous threats have been attacks on the financial sector. This report features threats with a particular focus on Europe, Russia, the US, Canada, and Australia. This document also provides a comprehensive description of threats to governments, including targeted attacks supported by governments and significant data leaks.

To collect data and inform our clients, we analyze various botnets and malware while conducting incident response, monitoring underground forums and accumulating information on new trends, threats, and data leaks. Every day we research thousands of compromised credentials, bank card numbers, hackers' accounts, messages, and announcements on the dark web, as well as tens of thousands of attacks, which enables us to promptly notify you of threats targeting your company and clients.

Executive summary

Targeted attacks on the financial sector

Q1 2020 saw the following APT campaigns against financial organizatons:

- Two attacks by the Cobalt group were discovered. The attacks took place on December 20 and February 3 and distributed Coblnt.
- December saw the discovery of Boostwrite malware samples of the Fin7 group and a new loader called Bioload and used for downloading the Carbanak backdoor. In February, Fin7 sent out letters with USB flash drives to targets in the US hospitality industry. Once connected to a computer, the USB drives delivered the Griffon malware.
- Silence started using a new version of the Silence.MainModule malware to attack targets in the medical and industrial sectors, which is not typical of the group.
- Previously undocumented tools used by Lazarus (North Korea) in their attacks against the financial sector were discovered, namely Lazarus.SvcRAT, BISTROMATH RAT, SLICKSHOES, CROWDEDFLOUNDER, HOTCROISSANT, ARTFULPIE, and BUFFETLINE.
- Group-IB experts investigated attacks the threat group RedCurl launched against financial, retail, travel, construction and insurance companies in the post-Soviet region, Europe, and North America.
- Group-IB specialists discovered and analyzed a campaign in which threat actors register similar-sounding domains mimicking the air travel industry, install Cobalt Strike on servers, send out phishing emails, and spread malware to compromise information.
- Group-IB specialists discovered phishing campaigns that targeted the customers of Japanese banks.

Financial threats

- Due to the COVID-19 pandemic, threat actors use this topic to send out numerous phishing emails to distribute malware (Trickbot, Emotet, NetWire RAT, Azorult, Lokibot, NetWalker ransomware, etc.) and compromise victims' accounts.
- Group-IB specialists discovered a new service for selling access to servers and corporate networks by the user with the nickname network. The threat actor is selling two types of access: domain admin access (access with administrator rights) and session access (e.g. Cobalt Strike or Armitage session). Compromised companies include banks, travel agencies, medical centers, universities, insurance companies, software developers, and so on; their number continues to increase.
- A mallicious mailout to Russian banks involving the naszBot malware was discovered.
- Active attacks involving RTM continue in the post-Soviet region: Russia, Kazakhstan, Ukraine, Belarus, and Azerbaijan.
- Trickbot acquired new features, such as a module for RDP brute-force attacks and the ability to bypass UAC in Windows 10; the malware continues to be used in attacks against banks in the US, the UK, Germany, Poland, and Japan. Trickbot has also actively been used to deliver other malware (such as Ryuk) together with Emotet.
  The attacked targets included Japanese, Australian, German, Polish, Canadian and UK banks, as well as banks in the US. Italy is a new target.
- The banking Trojan Retefe was used in attacks on banks in Europe (Switzerland, Norway, Liechtenstein, and Luxembourg).

- The geography of Gozi (aka ISFB) attacks has not changed; Gozi continues to be active in Australia, New Zealand and Italy.
- IcedID continues to attack banks in the US, Canada, and the UK.
- We did not record any activity of the Gootkit Trojan in Q1 2020.
- Danabot was observed in attacks on Australian, European, and US banks.
- It was detected that POS terminals at Landry's, a restaurant chain, and Rutter's, a chain of stores and gas stations, in the US were infected.
- Group-IB specialists analyzed a phishing campaign that targeted corporate users of Office 365. As a result of the attack, the threat actors could gain access to the entire email correspondence of their victims.
- In January, a database called BIGBADABOOM-III (BBB3 BREACH) with several million cards was put up for sale on Joker's Stash, a card shop. In their analysis, Group-IB specialists concluded that this was a result of compromise at Wawa, a US chain of convenience stores and gas stations.
- A new database of Malaysian bank cards was put up for sale on Joker's Stash, it was detected. The database contains 92,000 cards, which is a record number for the region.
- A database with 460,000 Indian cards was discovered.
- In February, a bank card database called NIRVANA BREACH containing about 400,000 compromised cards, was posted on Joker's Stash. The cards mainly belonged to US banks.
- Threat actors continue to actively use JS sniffers. Group-IB specialists detected the activity of sniffers such as GetBilling, Inter, Poter, PostEval, and others.
- As in previous quarters, FlexNet is the most dangerous banking Trojan for Russian users.
- The mobile banking Trojan Ginp attacks targets in Europe.
- Ramnit was active in Japan. It was distributed through GrandSoftEK. In addition, attacks targeting financial organizations in Italy were detected.
- A rootkit for Linux OS was put up for sale on an underground forum.
- A web server was discovered, on which software that automated SQL injections had been deployed. Attacks involving it targeted Japanese, South Korean and Taiwanese websites, it was observed.
- Attacks on Diebold Nixdorf ATMs were discovered in the UK. The threat actors used a modified version of software for Diebold Nixdorf ATMs, which resulted in the dispensing of cash.

Ransomware

- An attack by the Iron Tiger (Callypso) group that involved Hybird ransomware was detected in Thailand.
- The source code of notorious malware called Dharma (cryptolocker) was put up for sale on a Russian forum.
- A post about a partner program for another cryptolocker, NetWalker, appeared on an underground forum.
- January saw a Sodinokibi (REvil) attack against Travelex, a UK currency exchange company. The threat actors demanded a ransom of 6 million dollars. Travelex later said that they partially recovered the operation of affected systems having recovered the data.
- In February, Bretagne Télécom, a French telecommunications company, was attacked with the DoppelPaymer ransomware. The attack vector was the CVE-2019-19781 vulnerability in Citrix Application Delivery Controller.

- March saw a ransomware attack that paralyzed Finastra, a SWIFT provider for many banks. Neither the attack vector, nor the name of the ransomware used is known at the moment.
- Ryuk ransomware attacked companies EVRAZ and EMCOR.
  In the case of EVRAZ, one of the largest metallurgical and mining companies in the world, the ransomware managed to bring the company's operations in North America to a halt.
  EMCOR Group, which is in the Fortune 500 list, comprises 80 companies and does engineering and industrial construction. EMCOR said that only "certain IT systems" were affected. It was not mentioned whether the company paid the ransom.

Exploits

- In March, information was published about vulnerability CVE-2020-0796 in the SMBv3 protocol.
- The sale of a 1-day exploit for CVE-2019-1429, a remote code execution vulnerability in Internet Explorer, was detected.
- The sale of a 0-day exploit chain for iOS 13 was discovered on a Russian-speaking forum. The post raises doubts since the seller claims that being personally present at the European office of the company that is selling the exploit chain is required. This is unusual for the underground community.

Threats to the government sector

Governments are always going to be under the threat of cyberespionage and in some cases suffer attacks on critical infrastructure. Group-IB specialists perform an independent analysis of such threats and are well-informed about the results of global expert studies. The following APT campaigns against government organizations were detected in Q2 2020:

- Turla (Russia) carried out a watering hole campaign against Armenian government organizations using new tools, NetFlash and PyFlash. The group also attacked the Austrian Foreign Ministry.
- A phishing campaign was detected, which targeted the Ukrainian group of companies Burisma. APT28 (Russia) is believed to be behind the attack.
- Darkhotel (North Korea) is thought to have carried out an attack called Double Star using 0-day vulnerabilities in IE (CVE-2020-0674) and Firefox (CVE-2019-17026).
- OceanLotus (Vietnam) is believed to have registered domains that mimicked those of a Vietnamese oil and gas company and the State Bank of Vietnam.
- OilRig (Iran) attacked Bahrain's national oil company. The group sent out malicious documents posing as the research company Westat. In February 2020, a campaign called Fox Kitten was exposed. It started in at least 2017. The main targets were companies and organizations in the IT, telecommunications, oil and gas, aviation, and government sectors.
- A malware sample that had similarities with APT33's (Iran) backdoor was discovered.
- MuddyWater threat actors (Iran) seem to be continuing their campaign in which they distribute malicious documents targeting organizations in Turkey, Jordan, and Iraq, as well as intergovernmental organizations and other entities in Georgia and Azerbaijan.
- Charming Kitten (Iran) carried out attacks against journalists and political activists employing social engineering techniques.
- SideWinder hackers (India) used three malicious apps for Android and exploited CVE-2019-2215, a critical vulnerability.

- TA428 (China) used the conflict between Iran and the US as a topic to carry out attacks involving malicious documents with subsequent installation of PoisonIvy RAT.
- The cybergroup Intrusion Truth exposed new details about the activities of the state-sponsored hacking group APT40 (China). In addition, the Chinese hackers launched attacks against Malaysian government officials, it was observed.
- The hacking group Konni (North Korea) is carrying out a campaign named Fractured Statue using a new loader called CARROTBALL and decoy documents with text in Russian.
- Another Chinese group, Tick, is suspected of hacking Mitsubishi Electric, NEC, Kobe Steel Ltd., and Pasco Corp and stealing confidential data.
- Unknown hackers are using a new cloud Python RAT (remote access Trojan) called JhoneRAT to attack targets in the Middle East.
- The Transparent Tribe group (Pakistan) carried out phishing mailouts, including COVID-19–related (coronavirus) ones, in their attacks against India and infected victims using Crimson RAT.
- Gorgon Group (Pakistan) is believed to be continuing attacks as part of the Aggah campaign and is attacking Italian retailers.
- Unknown hackers compromised the UN Office of the High Commissioner for Human Rights, where they affected "core infrastructure," including systems for user and password management, system controls, and security firewalls.
- APT41 (China) attacked Hong Kong universities using an updated version of ShadowPad, it was observed. In addition, the attack against the German chemical company Lanxess was confirmed. Moreover, the hackers exploited vulnerabilities in Citrix, Cisco, and Zoho devices to attack industries such as banking/finance, construction, defense industrial base, government, healthcare, high technology, higher education, legal, manufacturing, media, non-profit, oil & gas, petrochemical, pharmaceutical, real estate, telecommunications, transportation, travel, and utility.
- Kimsuky hackers (North Korea) continued their wave of attacks as part of Operation Blue Estimate and used the COVID-19 topic as a lure.
- Gamaredon (Russia) carried out a number of new targeted attacks against Ukraine. In addition, it was observed that malicious emails, whose subjects included the COVID-19 topic, also hit Japan. It has not yet been determined whether Japan was targeted specifically, or if the hit was accidental.
- A new wave of attacks against Vietnamese targets was carried out by the Goblin Panda group (China). The hackers used Newcore RAT.
- The APT-C-23 group (Gaza) conducted a spear-phishing campaign against Israeli soldiers to collect data; the group carried out infections using Android Trojans.
- The Kwampirs group uses a similarly-named RAT to attack companies in the healthcare, energy, and finance industries using software providers in supply chain attacks.
- Holy Water campaign was discovered. It has been carried out since May 2019 and targets users in Asia. The main tactic is the watering hole technique against the webpages of religious figures, public bodies, and charities, with subsequent installation of a backdoor called Godlike12.
- Another previously unknown campaign was discovered in Q1 2020 — WildPressure. The group targets industrial facilities in the Middle East and its backdoor called Milum is in its early development stage.
- APT37 hackers (North Korea) carried out a new campaign called Operation Spy Cloud, in which they used Google Drive and PickCloud as command and control (C&C) servers, as well as to load malicious documents.
- It was revealed that in addition to Trojans for Windows, the BlackTech group uses the Trojans' variants to attack Linux, in particular Trojans TSCookie and PLEAD.

- Tonto Team (China) continues to improve their RAT called Bisonal in their cyberespionage campaigns against Russia, Japan, and South Korea.
- Gaza Cybergang hackers (Gaza) carried out a spear-phishing campaign against organizations in the government, telecommunications, insurance, and retail sectors in six countries.
- A group called Nuo Chong Lions was discovered. It remained undetected for years and attacked the Middle East; it carried out an attack against the opponents of the Saudi Arabian authorities. The attack involved expensive spyware.

Data leaks

- In late March, the data of 538 million users of the Chinese social networking service Weibo was put up for sale on an underground forum. The data included users' full names, usernames, gender, location, and phone numbers for 172 million users.
- Whisper, an application intended for anonymous exchange of posts and messages, put user data at risk. A 75-TB user database was publicly available. It contained about 900 million records.
- In March, an open database (AWS S3 bucket) of Merchant Cash Advance (MCA), an app for short-term loans, was exposed online. The 425-GB database contained about 500,000 documents of various financial companies.
- In February 2020, security researchers reported about a data breach affecting over 10.6 million people who had stayed at MGM Resorts hotels.
- The developers of Blisk browser caused a leak of user data by leaving an unprotected Elasticsearch server exposed online. The database contained about 2.9 million records.
- In March, 42 million accounts (IDs and phone numbers) of Iranian Telegram users were leaked online.
- An unprotected database that could belong to Keepnet Labs, an information security company, was found online. The discovered server contained over 5 billion records.
- Data leaks occurred at US medical companies Health Share of Oregon, Munson Healthcare, and Rady's Children's Hospital.
- An unprotected database of Tetrad, a marketing company, contained over 120 million records.
- An unprotected Microsoft database was found exposed on the web. It contained 250 million Microsoft customer service records for 2005–2019.
- In February 2020, the gaming website AnimeGame suffered a data breach. The leak contained 1.4 million records.

Forecasts for Q2 2020

- The Russian-speaking group Silence is likely to continue its expansion by multiplying their attacks outside Russia. To withdraw money, the group will carry out attacks on card processing systems and use Trojans for ATMs.
- Silence might stop attacking banks and start making money by encrypting data, a method other threat groups have been using lately.
- In their attacks, Silence might use the tools and infrastructure of the TA505 group.
- Lazarus will continue its attacks mainly in the Asian region, using ReconBackdoor, a recently detected tool called Lazarus.SvcRAT, and its newly developed tools.
- RTM will be a relevant threat to legal entities in the post-Soviet region.
- IT networks will remain the main attack vector for threat actors. Access to these segments is crucial for espionage and collecting information about how to attack a particular energy company for sabotage purposes. Network compromise will be the next step once the IT segment is successfully breached. Detecting network compromise is only possible in two cases: if the attack is designed for sabotage purposes or if the malware operator makes a mistake. For this reason, attackers often try to be as covert as possible until they must carry out a mass attack.
- Supply chain attacks will pose a serious problem for the energy sector from the part of various software and hardware providers. Management companies will be attacked first, then used to penetrate networks belonging to energy companies. The most significant threat is expected to come from developed countries. Threat actors in such regions are better equipped, which is why their activity is less noticeable and less thoroughly investigated.
- Cybercriminals are increasingly shifting to social engineering from traditional ways of stealing money from bank accounts. Last year, up to 70% of thefts from the bank accounts of Russian banks' customers were carried out involving the account and bank card owners themselves, i.e. using social engineering techniques, Russia's Central Bank estimated.
- Due to the COVID-19 pandemic, mailouts on this topic will continue. We advise being extremely cautious about such emails, since most of them are malicious or fraudulent.
- Credit card sniffers will remain a relevant threat. Group-IB specialists continue to detect infections on many websites.
- The number of ransomware attacks will only increase.
- We will discover new card databases resulting from the compromise of POS terminals. This will mostly occur in North America.
- The banking Trojan Retefe will be used to attack banks in Europe.
- The Fin7 group will continue its attacks within and outside Russia and will use the Griffon malware.
- FlexNet will attack users of Android mobile devices in Russia.
- The banking Trojan Ramnit will be a relevant threat for Japan. It might also attack some European banks and financial organizations.
- Thefts involving Danabot will continue in Australia, North America, and Europe.
- The geographical scope of Trickbot will be as large, but this Trojan will also be active in Japan.
- Icedid will primarily be active in the US, Canada, and the UK.
- Gozi will mostly be active in Australia, New Zealand, and Italy.
- The Android banking Trojan Ginp, which is based on the Anubis source code, will be used in attacks against users in Europe, Australia, and North America.

Advanced threats in the financial sector

333

APT name	Regions attacked		Related notifications	Operation start
Cobalt	Global		CP-1438-83	2016

In Q1 2020, Cobalt was not as active as previously and only carried out a few attacks.

On December 20, 2019, .scr files were uploaded to VirusTotal. The files had been used to distribute the Coblnt malware. Interestingly, a .vhd file was discovered, which was used as a container for these files. The threat actors used the .vhd file to bypass MOTW (Mark of the Web) detection of the malicious files. Prior to that, they had registered a domain that they used as a command and control (C&C) server.

On February 3, an .exe file was uploaded to VirusTotal. The file, which was classified as Coblnt, was compiled on January 23. It downloads payload from a domain registered on January 22.

Cobalt is a Russian-speaking cybercriminal group active since April 2016. Their attacks target the internal infrastructure of banks and organizations that have common infrastructure with banks (leasing and insurance companies) in Eastern Europe, post-Soviet countries, the Asia-Pacific region, and other areas. Their aim is to gain access to ATM, bank card and interbank transfer management systems. To carry out their attacks, the group mostly uses phishing emails disguised as coming from financial organizations and ATM manufacturers. The emails contain malicious attachments in the form of a document with an exploit or password-protected archive with an executable within.

APT name	Regions attacked	Operation start
Fin7	Global	December 2019

On December 26, 2019, security specialists reported about recently discovered files of the Fin7 threat group. Some of them are classified as Boostwrite, the rest are a new malicious loader called BIOLOAD, which has code similarities with Boostwrite and is used to download the Carbanak backdoor.

The attackers applied the DLL search order hijacking technique and a scheduled task to ensure persistence.

BIOLOAD is placed together with a legitimate file in the WinBioPlugIns folder. For a successful attack, the threat actors need to first escalate privileges.

BIOLOAD has encrypted Carbanak payload. To decrypt the payload, it uses XOR. Fetching the key does not require accessing the C&C server; the key is embedded in the loader but it is customized for every victim and is derived from the name of the infected machine. The final payload is the Carbanak backdoor, with timestamps from January and April 2019.

In February 2020, the US hospitality industry suffered attacks associated with Fin7.

The threat actors sent out an actual letter disguised as coming from BestBuy. The letter included a $50 gift card and a USB flash drive, which purported to contain a list of products the gift card could be used for.

The USB device was programmed to emulate a USB keyboard. Once it is plugged in, the keyboard emulator can automatically inject malicious commands. The payload is a PowerShell script obfuscated using the Caesar cipher (shift = 1). The deobfuscated PowerShell command downloads the second stage PowerShell code from hxxps://milkmovemoney[.]com/st/mi.ini.

The second-stage Powershell performs the following actions:

1. Copies "wscript.exe" to %AppData%\Microsoft\Windows\wipre.exe
2. Decodes JScript (third-stage payload) and saves it as prada.txt
3. Executes prada.txt with the command cmd.exe /c wipre.exe /e:jscript prada.txt
4. Shows a fake warning with the following text: "The last USB device you connected to this computer malfunctioned, and Windows does not recognize it."

The script is the Griffon malware and is executed through "wscript.exe." It is obfuscated and used for sending unique victim ID to the C&C server through an HTTP request. The server responds with encoded data and a XOR key to decode it. The decoded data is an additional Jscript code, which is executed on the infected machine and collects system information (username; hostname; user's system privilege; uses WMI query to get the: process owner, domain name, computer model, operating system information; Office and Adobe acrobat installation; list of running processes; and whether the infected host is running in a virtualized environment). The gathered information is sent to the C&C server. The main Jscript code enters an infinite loop sleeping for 2 minutes in each loop iteration then getting a new command from the C&C server.

Fin7 is a financially motivated Russian-speaking criminal group active since 2015. The threat actors use social engineering techniques and periodically update their attack methods and tools in an effort to bypass detection mechanisms. Most of their attacks target hospitality and restaurant businesses in Europe and the United States.

APT name	Regions attacked	Operation start
Silence	Global	January 2020

On February 27, 2020, a file called "antrem.exe," which is classified as Silence.ProxyBot, was uploaded to VirusTotal. The address 195.123.246.126 was used as the C&C server. Analysis revealed two more files, both Silence.MainModule:

- service.exe
- services.exe

Both files are new versions of Silence.MainModule.

The analysis revealed that the server 195.123.246.126 had been active since at least January 2020. Historical data helped discover that the following files could be downloaded from this server during the attack:

- comahawk.exe — an LPE exploit for vulnerabilities CVE-2019-1405 and CVE-2019-1322 with the aim of escalating privileges.
- wsus.exe — a meterpreter stager packed with TA505's TinyMet packer. The application receives protocol type, address and port of the payload (meterpreter) as arguments upon launch. It was

not possible to obtain the payload address during analysis. We have earlier issued notification alerts about Silence attacks that involved tools attributed to the TA505 group.

The analysis revealed two victims, both in Western Europe: a medical company and an industrial company. Both victims are not typical of Silence, which used to attack the banking sector exclusively. This could suggest the following:

- Silence decided to carry out ransomware attacks.
- Silence's tools have been sold/given to other threat actors responsible for this attack.
- The attack is a stage in a supply chain attack.

Silence is a financially motivated cybercriminal group active since 2016. Their attacks mostly target post-Soviet countries, but the group has been gradually going global.

APT name	Regions attacked	Operation start
Lazarus	Global, Pakistan, Vietnam, Thailand	2018

In February 2020, the US Cyber Command published information on six new malicious tools of the north Korean threat group. The US authorities believe this malware is used in a new phishing campaign with the aim of stealing funds.

The list of tools includes BISTROMATH, a “full-featured” Remote Access Trojan (RAT); a loader called SLICKSHOES; CROWDEDFLOUNDER malware designed to unpack and execute a RAT binary in memory; HOTCROISSANT described as a "a full-featured beaconing implant" used for "conducting system surveys, file upload/download, process and command execution, and performing screen captures"; ARTFULPIE for loading DLLs; and BUFFETLINE for downloading, uploading, deleting, and executing files, enabling Windows CLI access, creating and terminating processes, and performing target system enumeration.

On March 5, 2020, Group-IB specialists discovered an unknown tool of Lazarus, which was dubbed Lazarus.SvcRAT. This RAT was used in attacks a year ago. It was downloaded to victim devices through Lazarus.NETLoader and remained undetected for a long time.

The set of analyzed programs contains numerous malicious utilities, which include the PowerShell-based Lazarus.ReconBackdoor agent and a new backdoor that can be classified as Lazarus.SvcRAT. ReconBackdoor can receive and execute payload as additional PS scripts, as well as .exe files. This can significantly extend the ReconBackdoor functionality. Supposedly, this is how the SvcRAT backdoor gets into the system — through a command from the ReconBackdoor operator. The backdoor persists in the system as a service by using the system process svchost.exe. To function, backdoor samples need certain command line arguments, or an external config file (which is located next to a DLL and has the .mui extension) — they determine what C&C server the backdoor will connect to and request commands from and how often it will do that. SvcRAT is a Trojan and has all the necessary functionality to take control over a target system and attack other systems in the local network.

Lazarus (also known as Dark Seoul Gang, HIDDEN COBRA, Guardians of Peace) is a cybercriminal group active since 2007. Specialists have established that the group’s members are from North Korea.

Threat name	Detection	Regions attacked
RedCurl	2018	Post-Soviet region, Europe, North America

Group-IB experts investigated attacks the threat group RedCurl launched against financial, retail, travel, construction and insurance companies in the post-Soviet region, Europe, and North America.

During the attack, the hackers download all Office documents, text files, and images. In some cases, they install Monero miners in compromised infrastructures. Their activity was first recorded in 2018. The threat actors register victim-specific domains and then send out emails from publicly available email services, having connected the domain to these services; for instance, yandex.ru. The email body contains a link, supposedly to information on premium features of public file storage services, e.g. dropbox.com, or to a rented-out server where a self-extracting SFX RAR archive with a PDF icon is located.

The initial stage involves a custom PowerShell-based Trojan that uses curl and 7z. The tool was dubbed RedCurl.FirstStageAgent.ps1. It does not directly connect to the threat actors' server, instead network drives are mounted using public cloud services such as opendrive.com, pcloud.com, driveonweb.de, cloudme.com, powerfolder.com, box.com, koofr.net, idata.uz, and drivehq.com. Data is then uploaded to a file in the cloud. The operator, in turn, connects to the cloud service to download the data. This means that there is no direct interaction between the victim's infrastructure and the threat actor. All communication involves a legitimate service.

The threat actors moved laterally across the network as follows: the first stage involves pypykatz and lazagne. Pypykatz is a Mimikatz implementation in Python and is used for extracting credentials. Lazagne is a tool for extracting passwords from various types of clients such as email, browsers, etc.

Next, the ssh.exe utility is used to create a tunnel. If this attempt fails, a technique involving .lnk shortcut files can be used.

The threat actors create shortcut files for documents on network drives that employees use. The shortcut files are designed to download and execute RedCurl.Dropper when the documents are opened. The attackers then simply wait until someone among the employees opens the documents.

For analyzing corporate network topology, the attackers use the adexplorer utility from the Sysinternals Suite as well as various Windows system utilities.

Threat name	Detection	Regions attacked	Related notifications
Attacks involving phishing against companies in the air transport industry	November 2019	Global	CP-2223

Group-IB specialists discovered a campaign that mainly targets air transport companies and related services. In this campaign, threat actors register similar-sounding domains, install Cobalt Strike on servers, send out phishing emails, and spread malware to compromise information. It was revealed, that the

threat actors had registered domains that mimicked Boeing, General Electric, Falcon Aerospace, Lufthansa, Honeywell, numerous airports, and so on. The distributed malware mostly involved Formbook formgrabber.

Threat name	Detection	Regions attacked	Related notifications
Phishing attacks against customers of Japanese banks	February 2020	Japan	CP-2207

On February 14, 2020, Group-IB specialists discovered phishing campaigns that targeted the customers of Japanese banks.

The analysis of the control panel revealed that it collected data from various phishing campaigns. The following information is saved to the control panel database:

- Login-password pairs, additionally account number
- Victim's IP address
- Victim's browser information
- Victim's name and other personal data
- Account creation time
- Session information
- Unique panel user name |Short name of the phishing campaign
- Data source | Short name of the targeted resource

The following targets were identified:

- smbc.co.jp
- mizuho-fg.com
- japannetbank.co.jp
- mufg.jp
- fukuokabank.co.jp
- aeonbank.co.jp

Financial threats

Malware for Android

Threat name	Detection	Regions attacked
FlexNet	2014	Russia

The Trojan requests device administrative privileges. The request text is masqueraded as a Google Play agreement, which distracts the user and helps access the privileges.

On command from the C&C server, the application can do the following:

- change the C&C server address
- send an SMS message to a specified number
- send bulk SMS messages with a specified text
- forward SMS messages to a remote server
- reply to SMS messages and delete them to conceal the fact from the user
- run USSD requests
- schedule commands: configure a command template for new bots for a particular operator and country

In addition, FlexNet had phishing dialogs added to its functionality. They are disguised as popular applications in order to obtain victims' bank card details. The following fake dialog boxes were detected:

AliExpress
Alpha
Avito
Google Play
MyNewAlpha
telecard
VTB24
Sberbank
Uber

Threat name	Detection	Regions attacked
Ginp	2019	Europe

Ginp is a new banking Trojan for Android. It emerged in late 2019 and is based on the Anubis source code. In their attacks, threat actors can use web fakes developed to specifically target various banks; in Q1 2020, such attacks targeted Spanish banks. Threat actors also use web fakes for regular applications such as Google Play Verificator, WhatsApp, Skype, Twitter, Snapchat, and Viber to compromise victims' data.

Threats and malware for PC

Threat name	Detection	Regions attacked	Related notifications
Malicious mailout involving naszBot malware	February 2020	Russia	CP-2178

Early February saw a malicious mailout to Russian banks. The infection involves several stages and results in a loader called naszBot being launched on victim devices.

The infection process can be divided into four stages. The first stage involves the reception of payload from a legitimate resource, pastebin.com. A user with the nickname Broadland uploads the second-stage payload to that service. Further analysis revealed that the first stage of the infection was carried out using that service and was not a unique tool of any group (for instance, our analysis revealed samples Dridex, Locky, REMCOS, and NetWire, which are delivered to victim devices similarly).

The second stage is a loader application that receives payload from an image and launches it.

During the third stage, a malicious application is launched on the infected device. On command from the server, the application can collect and transfer information about the computer, as well as download and launch payload. This malware was classified as naszBot (the application uses Polish words for commands). Presently, it has not been possible to establish whether naszBot is a new tool of the TA505 group or of a different threat group.

It was not possible to obtain the fourth stage during the analysis.

Threat name	Detection	Regions attacked	Related notifications
Phishing campaign against corporate Office 365 users	March 2020	Global	CP-2228

In March 2020, Group-IB specialists discovered a phishing campaign that targeted corporate users of Office 365. In this campaign, threat actors distributed links to a legitimate Microsoft website in spam emails disguised as a notification about a new OneDrive document available. While the link redirected to a legitimate Microsoft website, it was a request to gain access to an Office 365 account from a malicious application. If the user entered their credentials and then allowed the application access to the account, the application, which was written in Go, gained access to all email correspondence of the victim, including all new emails, since it supported synchronization. Analysis of the malicious code revealed that the malware searched for emails related to money transfers and financial transactions in the compromised accounts. This means that the threat actors' ultimate goal presumably was business email compromise BEC. As at April 1, 2020, the number of compromised accounts had reached 295.

Threat name	Detection	Regions attacked

Retefe	2014	Norway, Switzerland, Liechtenstein, Luxembourg, Sweden

Retefe is a banking Trojan discovered in 2014 and written in JavaScript. It redirects users to fake online banking webpages using a forged certificate and the Tor network and compromises popular web browsers, including Internet Explorer, Mozilla Firefox, and Google Chrome. In 2017, a macOS version known as Dok emerged, which was followed by a version that used the EternalBlue exploit.

Group-IB specialists analyzed Retefe samples that attacked Norwegian and Swedish banks in Q1 2020:

banknorwegian.no
nettkonto.no
fanasparebank.no
monobank.no
portalbank.no
dnb.no
landkredittbank.no
netfonds.no
santanderconsumer.no
storebrand.no
instabank.no
bnbank.no
seb.no
nettbankportal.no
nordea.no
sparebank1.no
paretobank.no
flekkefjordsparebank.no
oest.no
spareskillingsbanken.no
sgsparebank.no
vossabanken.no
sor.no
hsb.no
luster-sparebank.no
skudeaakra.no
lillesands-sparebank.no
handelsbanken.no
ssf.no
dvbbank.com
spv.no
danskebank.no
nordnet.no
sbanken.no
sveaekonomi.se
sveadirekt.se

As well as Swiss, Liechtenstein, and Luxembourg banks:

akb.ch
ubs.com
bkb.ch
lukb.ch
zkb.ch
onba.ch
gkb.ch
bekb.ch
zugerkb.ch
bcge.ch
credit-suisse.com
bcvs.ch
cic.ch
ukb.ch
urkb.ch
eek.ch
szkb.ch
shkb.ch
glkb.ch
nkb.ch
owkb.ch
cash.ch
bcf.ch
bcv.ch

juliusbaer.com
abs.ch
bcn.ch
blkb.ch
bcj.ch
zuercherlandbank.ch
bankthalwil.ch
piguetgalland.ch
inlinea.ch
bernerlandbank.ch
bancasempione.ch
bsibank.com
corneronline.ch
vermoegenszentrum.ch
gobanking.ch
slbucheggberg.ch
slfrutigen.ch
hypobank.ch
regiobank.ch
rbm.ch
ersparniskasse.ch
ekr.ch
sparkasse-dielsdorf.ch
eki.ch
bankgantrisch.ch
bbobank.ch
alpharheintalbank.ch
aekbank.ch
acrevis.ch
credinvest.ch
zarattinibank.ch
appkb.ch
arabbank.ch
apbank.ch
bankbiz.ch
bankleerau.ch
btv3banken.ch
dcbank.ch
bordier.com
banquethaler.com
bankzimmerberg.ch
bbva.ch
bankhaus-jungholz.ch
sparhafen.ch
banquecramer.ch
banqueduleman.ch
bcp.bank
bil.com
vontobel.com
pbgate.net
bnpparibas.com
ceanet.ch
ce-riviera.ch
cedc.ch
cmvsa.ch
ekaffoltern.ch
glarner-regionalbank.ch
cen.ch
cbhbank.com
coutts.com
cimbanque.net
commerzbank.com
efginternational.com
falconpb.com
gemeinschaftsbank.ch
frankfurter-bankgesellschaft.com
globalance-bank.com
ca-nextbank.ch
hsbcprivatebank.com
leihkasse-stammheim.ch
lienhardt.ch
maerki-baumann.ch
mirabaud.com
pbihag.ch
rahnbodmer.ch
mybancaria.ch
reyl.com
saanenbank.ch
sebgroup.com
slguerbetal.ch
bankslm.ch
neuehelvetischebank.ch
slr.ch
slwynigen.ch
sparkasse.ch
trafina.ch
ubp.com
direct.directnet.com

tkb.ch
onlinebanking.directnet.com
nab.ch
cler.ch
llb.li
bankfrick.li
vpbank.com
bankalpinum.com
unionbankag.com
neuebankag.li
raiffeisen.li
volksbank.li
bendura.li
lgt.com
mirabaud.lu
bankbsu.ch
sigmabank.com
mason-privatbank.li
helvetischebank.ch

Threat name	Detection	Regions attacked
Trickbot	2016	USA Austria UK Germany Poland Japan Canada

Trickbot is a banking Trojan that uses techniques similar to those of Dyre. It is distributed through email spam. Lately, however, it has often been distributed using Emotet.

In 2020, Trickbot samples with new features were discovered:

- bypassing UAC in Windows 10 (it was previously available only for Windows 7) to deliver malware to numerous machines in the network
- using Windows 10 ActiveX to execute malicious macros
- module for using hacked machines for RDP brute-force attacks

Analysis of detected samples showed that in Q1 2020 Trickbot attacks targeted the following banks (examples):

Capital One
Citi
Noris bank (DE)
BBT.com
Sparda (DE)
Wells Fargo
USBank
Centrum24 (PL)
Commonwealth
ANZ
BBVA
Chase
Halifax
Rakuten
Keiyobank
Mizunobank
Hokkokubank
Fukuokabank
Resonabank
Kumamotobank
berliner-bank.de
deutsche-bank.de
capitalone.com
royalbank.com
haspa.de
ing.de
ingbank.pl
ing-diba.de

nab.com.au
cibc.com
online.citi.com
poste.it
cbibanking.it
bancagenerali.it
popso.it
bnl.it
credit-agricole.it
bankaustria.at
bankofamerica.com
unicredit.it
bancobpm.it
credem.it
carispezia.it
relaxbanking.it
dbonline.italy.db.com

Threat name	Detection	Regions attacked
Gozi (ISFB, Ursnif, Dreambot)	2007	Australia, New Zealand, Italy

In Q1 2020, we detected Gozi attacks in Australia, New Zealand, and Italy.

Examples of targeted banks in Australia and New Zealand:
ANZ
Bankwest
Bendigobank
Commonwealth
NAB
ING AU
Bankofmelbourne
BankSA
Stgeorge
Westpac
ASB
Australianmilitarybank
Adelaidebank

Targeted banks in Italy:

tecmarket.it
cbibanking.it
cim-italia.it
credem.it
fideuramonline.it
bcp.it
mps.it
sella.it
cabel.it
fmbcc.bcc.it
bancapassadore.it
bancobpm.it
finecobank.com
nowbankingcorporate.it
credit-agricole.it
brsspa.it
banking4you.it
nexi.it
ing.it
cariparma.it
bancagenerali.it
poste.it
hellobank.it
gruppocarige.it
chebanca.it
bancaeuro.it
icbpi.it
inbank.it
italy.db.com
bancaprossima.com
pec.it
vianova.it

popso.it
unipolbanca.it
chebanca.net
relaxbanking.it
tim.it
csebo.it
unicredit.it
ubibanca.com
bnl.it
cedacri.it

Threat name	Detection	Regions attacked
IcedID (aka Bokbot)	2017	USA, Canada, UK

IcedID was first detected in late 2017. The malware can be used to steal financial information and launch targeted attacks. IcedID is mostly distributed using Emotet but also through phishing emails with a malicious macro that downloads and launches IcedID.

IcedID has a modular architecture and functionality comparable to Zeus, including web injects, data theft, and the ability to inject code into other processes. One of the bot's specific characteristics is its ability to deploy a proxy server on an infected machine and redirect all internet traffic using that server.

In addition to banks, IcedID currently attacks e-commerce businesses. In either case, the criminals' aim is to obtain bank card details: card number, CVV, expiration date, and the region where the victim is located.

The detected IcedID samples target banks in the US, Canada, and the UK, as well as e-commerce vendors.

Known targets:

HSBC Bank
Royal Bank of Canada
JPMorgan
Citibank
Bank of America
The Synovus Financial Corporation
Toronto-Dominion Bank (TD BANK)
Chase Bank
Charles Schwab Corporation
Fifth Third Bank (53 bank)
Post Oak Bank (US)
Halifax
Usbank
Unionbank (US)
USAA Bank
Canadian Imperial Bank of Commerce
Mandtbank

Threat name	Detection	Regions attacked

RTM	2015	Russia, Belarus, Kazakhstan, Ukraine, Azerbaijan

The program is written in Delphi and is a modular Trojan. Judging by its functionality, the Trojan targets remote banking services and payment systems. Its latest tracked sample searched for the following remote banking services on infected machines: BSS_PC, Faktura, HandyBank, QiwiCashier, Raiffeisen, RosBank, SberBank_BO, SberBank_Fiz, SberBank_PC, and VTB24.

The RTM group has a main panel and a separate Proxy panel showing banks they target specifically: all requests are sent to phishing servers where the traffic is proxied.

Since early 2019, mass emails that distribute the RTM Trojan have continued to be actively sent out. We detect such emails almost every day. The recipients are Russian-speaking legal entities.

In late 2019, it was established that RTM was involved in attacks on legal entities in Belarus. The remote banking systems of the following banks were targeted: Belarusbank, BPS-Sberbank, BelVEB, BSB Bank, Belgazprombank, Alfa-Bank, Belinvestbank, Idea Bank, Paritetbank, MTBank, StatusBank, and Belagroprombank.

The malware's main targets are small and medium-sized businesses. However, computers in the infrastructures of large businesses and government agencies are also targeted.

Threat name	Detection	Regions attacked
Danabot	2018	Australia, Europe, USA

The modular banking Trojan Danabot was first detected in the spring of 2018. It uses web injects and intercepts victims' data. It has VNC, Sniffer, Stealer, TOR and RDPWrap modules.

New features were later added to it, namely, several layers of encryption for transferring data to the C&C server and a new loader component with an ability to load plugins along with the main module, which makes it an even greater threat.

In Q1 2020, we detected Danabot that attacked Australian targets, among which are the following banks:

Australia and New Zealand Banking Group
Westpac
Bank of Melbourne
Bank of South Australia (BankSA)
St.George Bank
Commonwealth Bank of Australia
National Australia Bank

Other researchers say they detected samples that targeted banks in Europe (Poland, Germany, Austria, and Italy) and the United States: bankofamerica, wellsfargo, tdbank, royalbank, rbcroyalbank.

Threat name	Detection	Regions attacked
Ramnit	2010	Japan, Italy

The banking Trojan Ramnit was first discovered in 2010. In 2015, the Ramnit botnet was taken down by a joint international operation coordinated by Europol. The Trojan's activity, however, did not stop and it continued to be used to compromise bank cards in North America and Europe up until the beginning of 2018. It was followed by a lull, but in Q3 2018 Ramnit resumed its activity. The threat actors focused on attacks against Japan and the United States, occasionally targeting European banks.

In Q1 2020, researchers noted that Ramnit continued to attack banks in Japan; the distribution method was GrandSoft EK.

Known Ramnit targets:
Credit Saison
Idemitsu Credit Co.
Mitsubishi UFJ NICOS Co
Aeon Bank
Life Card Co.
Pocket Card Co.
Cedyna Financial Corporation
Epos Card Co.
Rakuten
Sumimoto Mitsui Card Co.

There is also information that there have been attacks on Italian financial organizations.

Threat name	Detection	Regions attacked	Related notifications
Sale of compromised cards of Malaysian banks	January 2020	Malaysia	CP-2140

In early January, Group-IB's monitoring of card shops revealed a new database on Joker's Stash, a resource for selling bank card data. The database is called NO-CVV-MIX and contains over 92,000 "CCs" (textual bank card data) without CVV/CVC information. Over 99.7% of the cards from this database belong to Malaysian banks. This spike is atypical and unprecedented for the region. At the moment, the source of the compromise of the cards from the NO-CVV-MIX database has not been established.

Threat name	Detection	Regions attacked	Related notifications
Sale of compromised cards of Indian banks	February 2020	India	CP-2175

Group-IB specialists discovered a database with over 460,000 bank card records on Joker's Stash, a card shop. Nearly 98% of the data belonged to the customers of major Indian banks.

Threat name	Detection	Regions attacked	Related notifications
Sale of compromised bank card database NIRVANA BREACH	February 2020	USA	CP-2179

In February, a bank card database called NIRVANA BREACH, which contained about 400,000 compromised cards, was posted on Joker's Stash, a card shop. The cards mainly belong to US banks.

Threat name	Detection	Regions attacked	Related notifications
Service for selling corporate network access by threat actor with the nickname network	November 2019	Global	CP-2185

In November 2019, a user with the nickname network made their first post about selling remote access to the corporate network of a European company on Exploit.in. The user also made posts about selling access to 40 different companies (banks, travel agencies, clinics, universities, insurers, software manufacturers, etc.) worldwide. The threat actor is selling two types of access: domain admin access (access with administrator rights) and session access (e.g. Cobalt Strike or Armitage session). As at March 2020, the service was active and kept adding new compromised companies.

Threat name	Detection	Regions attacked	Related notifications
Rootkit for Linux OS	January 2020	Global	CP-2139

A user with the nickname pihte made a post on Exploit.in, an underground forum, about selling a rootkit for Linux OS.

The malware is based on hooking kernel functions and has the following functionality:

- Hiding network activity — tcp/udp/unix socket, listening/outgoing for all hidden processes
- Hiding processes and process hierarchies
- Hiding CPU usage
- Concealing files and changing their contents
- Disabling selinux for specified processes (in development)
- Not being detected by the latest versions of rkhunter/chkrootkit

The threat actor specified that the exploit worked on Linux only, but that it could be modified for other Unix-like systems, including older versions (BSD/ AIX / Solaris) if necessary.

The price for the malware is $10,000.

Threat name	Detection	Regions attacked	Related notifications
Software for automated website hacking	January 2020	Japan, South Korea, Taiwan	CP-2208

On January 9, 2020, a web server was discovered, on which software that automated SQL injections had been deployed.

The software makes it possible to carry out brute-force attacks on websites and attempts to find administrative panels. It then uses an add-in for SQLMap to try to extract databases from victim websites. Various post-exploitation scripts search for information about credit cards and various combinations of logins, passwords and hashes. The software uses a proxy to conceal its activity. The attacks mostly targeted Japanese, Taiwanese and South Korean websites. Some websites were successfully hacked, i.e. their databases were extracted.

Group-IB specialists notified relevant CERTs in these countries about this case. In addition, the alleged threat actor with the nickname Karabekian was profiled. It has been found that they are a Russian-speaking user registered on many hacker forums.

Attacks on ATMs and POS terminals

Threat name	Detection	Regions attacked
Compromise of Landry's restaurant chain	January 2020	USA

It was reported in January that a new malicious program emerged on the web. The malware was intended for collecting the data of bank cards that were used by restaurant and bar customers.

Specialists at Landry's believe only a small portion of data was breached, since the company faced a similar POS malware problem in 2016 and strengthened its security after the incident. Now they identified infections at 63 locations of the chain. The malware was active between March 13, 2019 and October 17, 2019. Some locations, however, were infected in January 2019.

Threat name	Detection	Regions attacked
Compromise of Rutter’s store chain	January 2020	USA

In an investigation, the chain of stores and gas stations Rutter's discovered unauthorozed access to bank card information on POS terminals at some of their gas stations and stores, which was caused by malware for POS terminals.

The company says that many locations use EMV POS terminals, which means that in the event of compromise, threat actors will only obtain card numbers and expiration dates and will not be able to get cardholder names or CVV codes.

The data breach in most of the locations where it was detected took place between October 1, 2018 and May 29, 2019.

Threat name	Detection	Regions attacked	Related notifications
Compromise of restaurant chain Wawa	January 2020	USA	CP-2164

On January 27, 2020, the first part of a new dump database called BIGBADABOOM-III (BBB3 BREACH) appeared on Joker's Stash, whose owner said that the full database contained over 30 million cards. The number of cards, the sale of magnetic stripe data (dumps) without PIN codes, and the fact that the cards' breakdown by banks is relatively even suggest that the source of the compromise was a network of trojanised POS terminals. Group-IB specialists analyzed bank cards from the BBB3 BREACH dump database and established that some of the cards from the BIGBADABOOM-III databases seemed to have been compromised at Wawa, a US chain of convenience stores and gas stations located along the East Coast of the United States. It is worth mentioning that on December 19, 2019, Wawa published an alert on their official website saying the payment systems at all their locations had been hacked. On January 29, this alert was updated with a message saying that the breached bank card data had been put up for sale on an underground resource, which the message did not mention.

Threat name	Detection	Regions attacked	Related notifications
ATM Trojan for Diebold Nixdorf	October 2019	Global	CP-2048

In late 2019 – early 2020, attacks on Diebold Nixdorf ATMs were detected in the UK. The threat actors used a modified version of software for Diebold Nixdorf ATMs, which resulted in the dispensing of cash.

The threat actors' tactic involved the following actions:

- Making a hole in the upper part of the front panel or removing the panel.
- Disconnecting the cable that goes to the ATM and connecting it to a laptop.
- Rolling back the ATM's security tools, most likely using modified software for Diebold Nixdorf ATMs.
- Sending commands to dispense cash.

The attack took 45-60 minutes, during which the threat actors used TeamViewer on the connected laptop.

Ransomware

Threat name	Detection	Regions attacked	Related notifications
Sale of source code of Dharma ransomware	March 2020	Global	CP-2235

Group-IB specialists discovered a post that advertised the sale of the source code of notorious malware called Dharma. The cryptolocker's source code, offered by the user dharmasource, had been obtained by reverse engineering an original malware sample. The package includes code in C, payload code, decryptor code, and console keygen. Dharmasource said the reason they were selling it was their moving on to something different.

The price of the source codes is $2,000. The seller says they are selling it to anyone interested.

Threat name	Detection	Regions attacked	Related notifications
NetWalker (MailTo) ransomware	March 2020	Global	CP-2229

In March 2020, a user named Bugatti made a post on underground forums exploit.in and xss.is about looking for advertisers to distribute their malware, NetWalker ransomware.

In their post, the threat actor said they were looking for advertisers who would help them distribute their malware. They needed someone who knew how to work with large networks. The author claimed that the malware had been operating since September 2019.

It is worth noting that this malware was used in attacks on healthcare centers. The malicious files were disguised as COVID-19 related documents.

Threat name	Detection	Regions attacked
Iron Tiger APT attack involving Hybird ransomware	March 2020	Thailand

On March 30, 2020, Group-IB specialists discovered a sample of Hybird ransomware on VirusTotal. The sample can be attributed to the Chinese APT group Iron Tiger (also known as Callypso and CharityWarriors). This ransomware was first used in an attack on a Malaysian bank in 2019.

Analysis of the new sample revealed that the victim was Charoen Pokphand Foods, a Thai agro-industrial company.

The attack vector is either a phishing email or vulnerability exploitation (it can be established in an incident response operation); further attack can involve tools such as Cosmosis, BNG Trojans, Callypso, or yLoader.

GLOBAL CYBER SECURITY COMPANY
GIB
GLOBAL CYBER SECURITY COMPANY

Exploits

Threat name	Detection	Regions attacked	Related notifications
CVE-2020-0796 vulnerability in the SMBv3 protocol	March 2020	Global	CP-2218

Information about CVE-2020-0796 was published on March 10, 2020. This is a critical buffer overflow vulnerability on Microsoft SMB servers. The problem occurs when vulnerable software handles a maliciously crafted compressed data packet. A remote, unauthenticated attacker can exploit this to execute arbitrary code within the context of the application.

The exploitation of this vulnerability could potentially cause mass distribution of malware similar to the WannaCry and Petya cases in 2017.

On March 13, 2020, Microsoft issued a patch for this vulnerability.

Threat name	Detection	Regions attacked	Related notifications
Sale of 1-day exploit for Internet Explorer (CVE-2019-1429)	March 2020	Global	CP-2234

Monitoring of the underground revealed a post on Exploit,in about the sale of a 1-day exploit for Internet Explorer. The author of the post is a user with the nickname rustaveli. The exploit the threat actor is selling targets the CVE-2019-1429 vulnerability. The author said the source code of this exploit had not been published and that it could be integrated into an exploit chain.

CVE-2019-1429 is a remote code execution (RCE) vulnerability, which exists in the way that the scripting engine handles objects in memory in Internet Explorer 9, 10, and 11. An attacker who has successfully exploited this vulnerability could execute arbitrary code on the victim's machine with the same user rights as the current user.

In addition, an attacker could host a specially crafted website that is designed to exploit the vulnerability through Internet Explorer and then convince a user to view the website.

On November 12, 2019, Microsoft released regular monthly security updates for their products, including Internet Explorer. The fixed vulnerabilities included CVE-2019-1429.

The price for the exploit was initially in the range between $20,000 and $50,000. However, on March 27, 2020, the author made a comment in the same thread, saying they were prepared to sell the exploit for $20,000.

Threat name	Detection	Regions attacked	Related notifications
Sale of a 0-day exploit chain for iOS 13	February 2020	Global	CP-2200

On February 23, 2020, a user with the nickname delgado made a post on Exploit.in about selling a chain of 0-day exploits for Apple devices running iOS 13.

According to the post the chain consists in exploiting:

- a remote code execution (RCE) vulnerability in Safari
- a local privilege escalation (LPE) vulnerability — kernel components vulnerability
- jailbreak — this vulnerability exists in Apple iPhone 6–11 running iOS 12.4 and later.

Once this exploit chain has been executed, a threat actor can launch a Mach-O executable bypassing the code signature verification process with root access rights and without sandbox limits.

This exploit chain does not require interaction with the user once the malicious link has been followed. In addition, the chain is not detected until the exploitation is finished and does not require developer and/or enterprise certificates. The exploit execution takes up to eight seconds on average.

In their post, the author noted that they were only an intermediary between buyers and the company that owned the exploit chain.

In addition, the seller said the chain was on offer for more than one person. The price is €2 million. Purchasing it requires being personally present at the company's European office.

It is worth mentioning that the author does not have reputation on the forum or any positive reviews of their work.

State-sponsored APTs

APT name	Regions attacked	Operation start
Turla	Armenia, Austria	2019

In March 2020, a watering hole attack carried out by Turla against Armenia since early 2019 was discovered. At least four websites were compromised during the attacks:

- The consular Section of the Embassy of Armenia in Russia
- Ministry of Nature Protection and Natural Resources of the Republic of Artsakh
- The Armenian Institute of International and Security Affairs
- The Armenian Deposit Guarantee Fund

The threat actors leveraged access to these websites to insert a piece of malicious JavaScript code. After a victim visits a compromised webpage, a second-stage malicious JavaScript is delivered, which is used to fingerprint the visitor's browser. The loaded script collects information including the browser plugin list, screen resolution, and various operating system information. The gathered data is sent to the C&C server in a POST request.

The threat actors are only interested in a limited range of targets, which is why if the visitor is deemed interesting, the server replies with a piece of JavaScript code that creates an iframe. The iframe displays a fake Adobe Flash update warning to the user. If the user clicks on the button, a malicious executable is downloaded. Once the malicious executable is downloaded and launched, malware together with a legitimate Adobe Flash program is installed.

Before September 2019, the threat actors distributed a malicious program called Skipper together with Adobe Flash. From September 2019, the C&C started delivering new payload, which was a .NET application that dropped a legitimate Adobe Flash installer and a new malicious loader called NetFlash. NetFlash downloads second-stage malware from a hardcoded URL and establishes persistence for this new backdoor using a Windows scheduled task.

The second-stage malware is a new backdoor called PyFlash, which is written in Python. The backdoor communicates with its hardcoded C&C server via HTTP. The C&C URL and other parameters such as the AES key and initialization vector IV are specified in the script. The main function of the backdoor is to collect and send information about the machine to the C&C server (systeminfo, tasklist, ipconfig, getmac, arp). The C&C server can send one of the following commands in JSON format:

- download additional files from a given link
- execute a Windows command using the Python function subprocess32.Popen
- change the execution delay: modifies the task that regularly launches the malware
- kill the malware

The output of the command is sent back to the server in encrypted form via a POST request.

In addition to attacks against Armenia, on January 4, 2020 the Austrian Foreign Ministry suffered an attack, whose aim is believed to have been cyberespionage. On February 14, 2020, it was announced that the threat actors' actions had been thwarted and that the attack had ended. The technical details are not revealed until the investigation is over.

In January 2020, an Austrian broadcaster revealed details about this attack, which it obtained from unofficial channels. According to these sources, there is a number of signs — including ones common with the 2017 Turla attack against the German Foreign Ministry — based on which this attack is attributed to Turla.

The attackers searched for documents related to Russia and Ukraine. The threat actors sent several employees emails with Christmas wishes and a malicious video in the attachment. Starting the video executed a small script, which requested a dropper from the C&C server. The downloaded dropper, in turn, downloaded a Trojan, which made it possible to gain access to the victim's email servers. As a result, employees' credentials and personal correspondence were compromised. The threat actors remained undetected for two days after the compromise took place.

There are two potentially coexisting theories about how this attack was discovered. The first one is confirmed by the Foreign Ministry's official statement and suggests that "anomalies" had been observed in the network. The second, unconfirmed theory states that the Austrian Foreign Ministry received a warning from a foreign agency saying that communication between their IP addresses and Turla C&C servers had been detected.

Turla is a Russian-speaking cybercriminal group believed to have been active since 2007. The main goal of Turla's attacks is stealing information from diplomatic, government, military, educational, research and pharmaceutical organizations.

APT name	Regions attacked	Operation start
APT28	Ukraine	November 2019

On January 12, 2020, information emerged about a phishing attack against the Ukrainian oil and gas group company Burisma. The campaign started in early November 2019 and is believed to have had political background. Researchers at Area1 believe APT28 could be behind the attack.

The threat actors registered lookalike domains that mimicked legitimate websites of Burisma subsidiaries and partners. In particular, domains targeting the following subsidiaries were discovered:

- KUB-Gas LLC
- Esko-Pivnich
- CUB Energy Inc.

The attackers faked services used within the company (Roundcube webmail login, SharePoint). To carry out the attack, the threat actors sent employees emails with links to login pages. These links looked like legitimate ones; in addition, the attackers set up sender authentication records using SPF and DKIM. Once the victim follows the link and enters their credentials, the attackers gain access to them and can use them to further the attack. Some employees entered their credentials on the fake webpages, which allowed the threat actors to stealthily operate within the organization and obtain the information they needed.

The researchers' evidence of APT28's involvement in the attack is based on the principles that formed the basis of some of the group's earlier attacks:

- Lookalike domains
- Use of Ititch, NameSilo, and NameCheap for domain registration

- MivoCloud and M247 as Internet Service Providers
- Yandex for MX record assignment
- Use of PositiveSSL certificates and the "Sharepoint" string in the domain names

In addition, a domain was discovered, which was registered in April 2019 and may have been used to attack Kvartal 95 Studio, a media organization created by the current Ukrainian president.

APT28 is a Russian-speaking cybercriminal group active since 2004. Most of the group's attacks have targeted political and military organizations, and, to a lesser extent, media outlets and sports organizations.

APT name	Regions attacked	Operation start
Darkhotel	Global	January 2020

January 2020 saw the discovery of attacks based on the exploitation of two 0-day vulnerabilities, in IE (CVE-2020-0674) and Firefox (CVE-2019-17026), which have been dubbed Double Star. The attacks have been attributed to the DarkHotel threat group. Exploiting these vulnerabilities allows attackers to execute arbitrary code on targeted machines. All they need to do is trick an IE or Firefox user to visit the malicious webpage.

While the attack could be carried out by distributing malicious links, the attackers also sent out emails with a malicious attachment, which was a document in Korean with an exploit for CVE-2017-11882. It is worth noting that CVE-2017-11882 allows for remote code execution without interaction with the user, which is why it is unclear what the threat actors' motives were to further exploit the CVE-2020-0674 vulnerability, which allows for the same activities. Opening the decoy document exploits the vulnerability, resulting in a malicious webpage being opened in IE, which is the start of the Double Star attack.

First, a shellcode is executed, which calls functions to launch WPAD. Next, the shellcode is run again, this time, however, it downloads a malicious file and obtains the OS version (in Windows 7, WPAD works with system privileges and threat actors do not need to take additional action; in Windows 10, WPAD is a local service, in which case they need to escalate privileges). The downloaded file is then launched; it receives commands from the hardcoded C&C and executes them.

DarkHotel is a cybercriminal group active since 2007 and believed to be based in North Korea. The group's primary targets are luxury hotel guests and political organizations mostly in North-East Asia. The aim of attacks is to collect confidential information and carry out cyberespionage.

APT name	Regions attacked	Operation start
OceanLotus	Vietnam	February 2020

On February 25, 2020, our early warning system for detecting malicious infrastructures exposed the domain portal-sbv[.]com, which was discovered based on rules developed to detect OceanLotus infrastructures. The domain mimics that of the State Bank of Vietnam.

On February 20, 2020, this domain had the A record 103.199.16.225. In its Location_Header, this IP address had the following domains specified: walmart.com and icloud.com. In addition, this IP address was specified as an A record for:

- petrolirnex[.]com on **February 12, 2020**
- 1tinhyeu[.]com on May 16, 2017
- congtykimthai[.]com on August 22, 2017
- thietbisuachuaotokimthai[.]com on July 19, 2017

The domain petrolirnex[.]com was created on February 11, 2020 and mimics Petrolimex, a Vietnamese oil and gas company. The domain's first A record is dated February 11, 2020 — 188.166.203[.]57. This IP address has been observed in OceanLotus attacks.

OceanLotus, also known as APT32, APT-C-00, SeaLotus, Sinh Tử Lệnh, Cobalt Kitty, and SectorF01, has been active since late 2009 and is believed to be based in Vietnam. The group attacked Vietnamese bloggers and dissidents and launched targeted attacks on industrial and government entities in Vietnam, Cambodia, China, Laos, the Philippines, Germany, and the United States. Apart from phishing emails, OceanLotus carries out watering hole attacks.

APT name	Regions attacked	Operation start
OilRig	Middle East, USA, Australia, France, Poland, Germany, Finland, Hungary, Italy, Austria	2017

According to Saudi Arabia's National Cybersecurity Authority (NCSC), Iranian state-sponsored hackers deployed a new strain of data-wiping malware on the network of Bapco, Bahrain's national oil company.

According to their data, the threat actors had urgency to launch the attack on December 29 due to multiple OPSEC failures observed on the infected network.

The threat actors gained initial access by exploiting a remote code execution vulnerability in a VPN appliance that was disclosed in July 2019. The attackers distributed and activated a wiper on all available devices; however, some machines were in the sleep mode and were not affected. The NCSC believes the files dropped by Dustman would have been detected by the networks' current antivirus, but the files bypassed antivirus detection. The threat actors either disabled the antivirus or whitelisted the EldoS RawDisk driver in order to allow malware execution.

Dustman seems to be a new variant of ZeroCleare, as the raw disk driver used by it shares the exact same digital fingerprint as the one utilized by ZeroCleare. In addition, both Dustman and ZeroCleare utilized the skeleton of the modified Turla Driver Loader (TDL), published in March 2019 on GitHub.

On January 28, 2020, several malware samples were uploaded to VirusTotal through the web interface from Lebanon. There were five samples in total: two executables .exe files, two.xls files, and one archive with an executable within.

One of the files mimics a document from the research company Westat. According to researchers at Intezer, this executable is a modified version of the TONEDEAF backdoor. They noted that the VBA code was similar to the one FireEye described in their report on TONEDEAF. Intezer researchers named this version of the malware TONEDEAF 2.0. The new version is different from the previous one in that it is stealthier and supports dynamic importing. In addition, it hides API imports. The names of these APIs, and the DLLs that contain them, are stored as encoded strings and are decoded and resolved on demand during runtime.

Interestingly, at almost the same time with this backdoor, a modified version of VALUEVAUL was uploaded to VirusTotal. VALUEVAUL had earlier been detected in a campaign together with TONEDEAF. Many functionalities and strings in this version of VALUEVAUL were deleted in order to lower its noise. Only Chrome password dumping to the file "fsociety.dat" remained.

Based on the main C&C server, Group-IB specialists uncovered the domain registration scheme, which allowed our system for detecting malicious domains to discover additional domains. One of them was mentioned in a report by the security company Telsy as a C&C server for other malware samples in Lebanon.

In February 2020, information about a malicious campaign came to light. The campaign had been ongoing for three years and was dubbed Fox Kitten by security researchers.

During this campaign, the threat actors gained access to and ensured persistence in the networks of numerous companies and organizations from the IT, telecommunications, oil and gas, aviation, and government sectors. This campaign was operated against organizations in Israel, the US, Saudi Arabia, Lebanon, Kuwait, the UAE, Australia, France, Poland, Germany, Finland, Hungary, Italy, and Austria. The main targets where researchers saw high activity were Israel, the US, and the Gulf countries.

In most cases, the initial infection of target organizations involved 1-day vulnerabilities in various VPN services such as Pulse Secure VPN, Fortinet VPN, and Palo Alto Networks' Global Protect. Upon gaining foothold at the target, the attackers tried to maintain the access to the networks by opening a variety of communication tools, including opening RDP links over SSH tunnelling. At the final stage, after successfully infiltrating the organization, the attackers performed the routine process of identification, examination, and filtering of sensitive, valuable information from every targeted organization.

The campaign involved red-teaming tools (some of which were open-source) together with the group's custom tools.

Researchers noted with medium-high probability that there were overlaps between this campaign's infrastructure and the activities of APT34. In addition, they identified, with medium probability, a connection between this campaign and APT33-Elfin and APT39-Chafer groups.

OilRig (also known as APT34) has been active since late 2015. The group is based in Iran and is believed to be linked to the Iranian government. The threat actors mainly target the banking sector, airlines, educational institutions, government entities, and IT and telecommunications companies. The group has had targets in Saudi Arabia, Turkey, Israel, Kuwait, Qatar, the US, the UAE, and Lebanon.

APT name	Regions attacked	Operation start
APT33	Middle East, USA	January 2020

On February 12, 2020, researchers at Telsy published a report describing a .NET malware sample. They said the sample, which they named POWERBAND, had similarities with POWERTON, a tool APT33 had used earlier.

The researchers said the similarities between POWERBAND and POWERTON were in command handling as well as almost identical encryption generation mechanisms.

POWERBAND starts by creating a structure that represents the victim's operating system state throughout the execution of the program, storing the current directory, the range of values for the sleep time and for the hibernation phase. In addition, it creates a unique identifier (called BKey) for each infected victim. Bkey is composed of MD5 of MachineName, UserDomainName and UserName, by taking in uppercase only the first 24 characters of the hash. The main usage of this MD5 value is to encrypt the machine's fingerprint information.

Fox Kitten campaign overlaps with the APT33 group:

In their report published on January 12, 2020, the security firm Dragos mentioned that the campaign they called Parisite had been developed to attack US electrical companies soon after the death of Qassem Soleimani. Dragos researchers mentioned a link they established between the Parisite campaign and

APT33 and highlighted the focus on IT companies. Their analysis revealed matches between some of the files used in the Parisite campaign and files and tools employed in the Fox Kitten campaign.

APT33 is a cybercriminal group active since at least 2012. The group targets organizations in different industries in the United States, Saudi Arabia, and South Korea. It is particularly interested in the aviation and energy sectors, which are closely connected with petrochemical production. The threat group is thought to be linked to the Iranian government and the Nasr institute, which has in turn been linked to the Iranian Cyber Army multiple times.

APT name	Regions attacked	Operation start
MuddyWater	Middle East, Azerbaijan, Georgia	mid-2019

According to researchers at Secureworks, the MuddyWater threat group continues their campaign, in which they spread malicious documents targeting organizations in Turkey, Joran, Iraq, as well as global intergovernmental organizations and unknown entities in Georgia and Azerbaijan. This campaign continued up until mid-January 2020.

The threat actors sent out phishing emails with XLS documents that contained malicious macros to infect their targets. Sometimes these macros delivered a RAT named ForeLord.

The DNS-based C&C protocol uses DNS_TYPE_TEXT records to transfer data. The ForeLord name reflects one of the DNS responses that the malware looks for as part of the C&C protocol: lordlordlordlord. This string is received from the C&C servers and acknowledges the reception of the message. The use of DNS tunneling means the requests are initially directed to legitimate DNS servers, which relay the requests to malicious nameservers controlled by the threat actors.

After gaining initial access to a host, the threat actors dropped several tools to collect credentials, test those credentials on the network, and create a reverse SSL tunnel. These tools included PASS32.dll, PASS64.dll, PasswordDumper.exe, Mimikatz, and CredNinja.

MuddyWater is a cybercriminal group active since 2017 mostly in the Middle East. The group's main activity is cyberespionage in pursuit of Iran's interests. The threat actor's targets are: government agencies and organizations, military entities, and petrochemical and telecommunications companies. The targets are located in Saudi Arabia, the UAE, the US, Israel, Iraq, India, Jordan, Egypt, Tunisia, Turkey, Tajikistan, Iran, Belarus, Russia, Uzbekistan, Georgia, and Pakistan. Most of the victims are in the Middle East.

APT name	Regions attacked	Operation start
Charming Kitten	Middle East, USA, UK, Europe	2019

In late January 2020, information appeared about a campaign conducted by the Charmin Kitten group against journalists and political activists. According to researchers at Certfa, this campaign is targeting private and government institutions, think tanks and academic institutions, and organizations with ties to the Baha'i community, and many others in European countries, the United States, United Kingdom, and Saudi Arabia.

The group sent out phishing emails posing as a Wall Street Journal journalist. The emails contained tracking links that the threat actors used to obtain basic information about the victim's device such as IP address, type of operating system, and browser. After establishing contact with the victim, the threat actors sent them a link to a page on Google Sites. This made the victims trust the destination domain and

follow the next link, which redirected to two-step-checkup[.]site, where the victims entered their credentials and two-factor authentication (2FA) codes for Google services.

The researchers also discovered a sample called "pdfreader.exe," which had backdoor functionality. They say that the authors of this malware are in direct contact with the people behind these phishing emails.

The Iranian threat group Charming Kitten has been carrying out attacks since at least 2013, it has been observed. The group focuses on individuals of interest to Iran who work in the fields of academic research, human rights, and media, with most victims located in Iran, the United States, Israel, and the UK. The hackers usually try to gain access to private email and Facebook accounts and sometimes establish a foothold on victim computers as a secondary objective.

APT name	Regions attacked	Operation start
SideWinder	Pakistan	March 2019

Trend Micro discovered three applications (Camero, FileCrypt Manager, and callCam) for Android associated with the SideWinder threat group, which specializes in cyberespionage.

The researchers say that these applications have exploited the critical CVE-2019-2215 vulnerability since at least March 2019. CVE-2019-2215 is a local privilege escalation vulnerability and can help an attacker get root access to the target device.

TrendMicro says FileCrypt Manager and Camero act as droppers. They communicate with the threat actors' C&C server to download a DEX file, which then downloads callCam and tries to install it using privilege escalation vulnerabilities or exploiting Accessibility Service. In addition to CVE-2019-2215, the malicious apps also attempt to exploit a vulnerability in MediaTek-SU driver to get root privilege, trying to ensure persistence in the system.

Once installed, callCam hides its icon from the user and collects and sends the following information to the C&C server:

- Location
- Battery status
- Files on device
- Installed app list
- Device information
- Sensor information
- Camera information
- Screenshot
- Account
- Wi-Fi information
- Data from WeChat, Outlook, Twitter, Yahoo Mail, Facebook, Gmail, and Chrome

SideWinder APT (also known as T-APT-04) is believed to be based in India. It is thought that the group's earliest attack was carried out in 2012. The threat actors' main objective is cyberespionage against military targets in South Asian countries, such as Pakistan.

APT name	Regions attacked	Operation start
TA428	India, Pakistan, East Asia	January 2020

In January 2020, a document called "How Swuleimani's death will affect India and Pakistan.doc" was discovered. It is directly related to the recent political events between Iran and the United States.

The document is in RTF format and has an OLE object related to Equation Editor. In recent years, these OLE objects have been a good indicator that a document may aim to exploit the CVE-2018-0798 vulnerability in order to infect the target with malware. This particular document is one of these examples and does it by dropping a binary called 8.t. in the "% TEMP%" folder of the user.

After this infection chain, a DLL executable file with the .wll extension was obtained; it is used for "Word.addin.8" files and is installed in the path "%APPDATA%\Microsoft\Word\STARTUP", which makes MSWord load this .wll executable file at the next application startup.

This DLL consists of a packed version of a PoisonIvy RAT sample, which after a few seconds sends traffic to the C&C server 95.179.131.29 through port 443, and in case of error — through port 8080 using HTTP traffic.

The tactics, techniques, and procedures (TTPs) described above coincide with those of a Chinese group known as TA428.

APT name	Regions attacked	Operation start
APT40	Malaysia	2019

The Intrusion Truth group continues to deanonymize Chinese state-sponsored hackers. This is the fourth operation they have exposed, having tracked down 13 front companies through which they say the Chinese state has been recruiting hackers.

These front companies use overlapping contact details, share office locations, and don't have any presence online except to recruit cyber-security experts with offensive security skills, using almost identical job ads. The technical job adverts that they have placed seek skills that would be suitable for red teaming and conducting cyber-attacks.

One of the companies is headquartered at the Hainan University's library and, Intrusion Truth says, has ties with a professor at the university's Information Security Department, who earlier managed an information security competition at the university and reportedly sought novel ways of cracking passwords, offering large amounts of money to those able to do so.

In February 2020, the Malaysian incident response team MyCERT warned about a cyberespionage campaign conducted by APT40 and aimed at Malaysian government officials. The attackers' aim was to steal confidential documents from government systems after infecting government officials' computers with malware.

The attacks involved spear-phishing emails sent to government officials.

MyCERT says the attackers posed as a journalist, an individual from a trade publication, or individuals from a relevant military organization or non-governmental organization (NGO).

The threat actors used malicious macros, which exploited two Office vulnerabilities (CVE-2014-6352 and CVE-2017-0199) to drop and execute the malware on the victim's computer.

The emails contained links to weaponized documents stored on Google Drive. Once the documents were opened, the victims were asked to enable the macros.

APT40 (also known as Leviathan, TEMP.Periscope, TEMP.Jumper, Bronze Mohawk, and Mudcarp) is a cyberespionage group sponsored by China and active since at least 2013. The threat actors hack the networks of defense organizations and steal confidential technical drawings and other information that can be used to modernize the Chinese navy and influence foreign elections.

APT name	Regions attacked	Operations start
Konni	Russia, USA	July 2019

In January 2020, a continued campaign associated with the Konni group was discovered. Between July 2019 and October 2019, multiple malware families were observed, which primarily targeted a US government agency, using the ongoing and heightened geopolitical relations issues surrounding North Korea to lure targets into opening malicious email attachments.

The malware families used in this campaign consisted mainly of malicious documents featuring CARROTBAT downloaders with SYSCON payloads, but also included a new malware downloader, which was dubbed CARROTBALL.

CARROTBALL, initially discovered in an attack in October 2019, is a simple FTP downloader utility that facilitates the installation of SYSCON, a full-featured Remote Access Trojan (RAT) that leverages FTP for C&C. It was found embedded in a malicious Word document sent as a phishing lure to a US government agency and two non-US foreign nationals professionally associated with North Korea.

Throughout the course of the campaign, security specialists ultimately observed a total of six unique malicious document lures sent as attachments from four unique Russian email addresses to ten unique targets. The subject matter of the lures featured articles written in Russian pertaining to ongoing geopolitical relations issues surrounding North Korea. Of those malicious documents, five contained CARROTBAT downloaders, and one contained CARROTBALL downloader. All malicious second-stage payloads were SYSCON.

The campaign was dubbed Fractured Statue and appears to have continued in January 2020. On January 14 and 15, 2020, documents that purported to be related to "Conference of the Central Committee of North Korea" and "Tokyo 2020 Paralympic Games" were created. The latter document's author is Georgy Toloraya, the text is in Russian and the internal code page is in Korean.

Originally, the name "Konni" was used to refer to a remote access Trojan utilized in targeted campaigns with strong links to North Korean interests. However, as additional campaigns began to appear with strongly overlapping TTPs yet did not feature the Konni RAT, specifically, some industry researchers simply began to adopt the Konni moniker to refer to the actors behind the aggregated set of activity.

APT name	Regions attacked	Operation start
Tick	Japan, China	June 2019

Mitsubishi Electric, one of the world's largest electronics manufacturers reported a security breach and data leak. The incident occurred as early as June 28, 2019, but the official internal investigation started only in September.

According to reports in local media, the intrusion was detected after Mitsubishi Electric staff found a suspicious file on one of the company's servers. It was revealed that the threat actors compromised an employee account in China and the attack then spread to Japan. It was reported that the hackers escalated their access from this initial entry point to Mitsubishi Electric's internal systems, gaining access to the networks of around 14 company departments, such as sales and the head administrative office.

Mitsubishi Electric did not deny that data exfiltration took place, but in its official statement, the company stressed that the intruders had not stolen data on its business partners and defense contracts. There is information, however, that the threat actors compromised Mitsubishi Electric's email exchange with the Defense Ministry and Nuclear Regulation Authority, as well as documents related to projects with private firms, including utilities, railways, automakers, and communications companies.

Besides Mitsubishi Electric, other defense contractors in Japan fell victim to cyberattacks, namely NEC, Kobe Steel Ltd., and Pasco Corp.

The Japanese IT and electronics giant NEC suffered numerous cyberattacks, resulting in nearly 27,000 files being stolen, including documents related to contracts with the country's Defense Ministry.

Japanese defense contractors Pasco Corporation (Pasco) and Kobe Steel (Kobelco) disclosed security breaches that happened in May 2018 and in June 2015/August 2016, respectively.

The geospatial provider Pasco and the major steel manufacturer Kobelco also confirmed unauthorized access to their internal networks during two incidents, as well as malware infections affecting their computing systems following the attacks.

At the moment, the cyberespionage group Tick is believed to be behind the attack. Tick (also known as Bronze Butler and REDBALDKNIGHT) has been active since at least 2008. The group primarily targets government agencies, IT companies, biotechnology firms, and the defense and electronics industries in South Korea and Japan.

APT name	Regions attacked	Operation start
New cloud Python RAT JhoneRAT attacks the Middle East	Saudi Arabia, Iraq, Egypt, Libya, Algeria, Morocco, Tunisia, Oman, Yemen, Syria, UAE, Kuwait, Bahrain, Lebanon	November 2019

Security researchers discovered a new RAT they called JhoneRAT. The RAT is dropped to victims via malicious Microsoft Office documents. The dropper, along with the Python RAT, attempts to gather information on the victim's machine and then uses multiple cloud services: Google Drive, Twitter, ImgBB, and Google Forms. The RAT attempts to download additional payloads and upload the information gathered during the reconnaissance phase. The Trojan attempts to target a very specific set of Arabic-speaking countries. The filtering is performed by checking the keyboard layout of the infected systems. Based on the analysed sample, JhoneRAT targets Saudi Arabia, Iraq, Egypt, Libya, Algeria, Morocco, Tunisia, Oman, Yemen, Syria, the UAE, Kuwait, Bahrain, and Lebanon.

The first document identified in phishing campaigns is called "Urgent.docx" and asks the recipient to enable editing in English and Arabic. The second one, "fb.docx," claims to contain data on a Facebook information leak, and the third document pretends to be from a legitimate UAE organization.

In each case, if editing is enabled, an additional Office document containing a malicious macro is loaded and executed. These documents are hosted on Google Drive to avoid URL blacklisting.

JhoneRAT is written in Python and is dropped through Google Drive, which hosts images with a base64-encoded binary appended at the end. These images, once loaded onto a machine susceptible to infection, will deploy the Trojan, which immediately begins harvesting information from the victim's machine including type, disk serial numbers, the operating system in use, and more.

When communicating with its C&C server in order to exfiltrate information, commands are checked via a public Twitter feed every 10 seconds. The handle @jhone87438316 was originally used, but this account has now been suspended.

The actual theft of data, however, is carried out through cloud providers ImgBB and both Google Drive and Forms. Screenshots are uploaded to ImgBB, binaries are downloaded from Drive, and commands are executed with output sent to Forms.

APT name	Regions attacked	Operation start
Transparent Tribe	India	January 2020

January 2020 saw new spear-phishing mailouts against India by the Transparent Tribe group. The emails contained links to download additional information. One mailout was masqueraded as related to the 72nd anniversary of the independence of the Indian Armed Forces. The second mailout involved a document that presented itself as a request for the DSOP FUND (Defence Services Officers Provident Fund), which is a fund where officers compulsorily deposit money to the government out of their salary on a monthly basis.

Both documents use macros to extract and execute PE files depending on the operating system version.

The .NET implant begins to load the recon actions, push a timer for the process to sleep, and tries to communicate with the C&C server. Once connection with the C&C server has been established, the malware sends information about the user, system, and installed antivirus software.

The malicious payload is the main component of the malicious implant Crimson RAT. Crimson is modular in the sense that additional payloads downloaded by the main RAT module are often utilized to perform functions such as keylogging and browser credential theft. The Crimson RAT is written in .NET.

In February 2020, Transparent Tribe carried out a wave of attacks involving the coronavirus topic. The group used spear-phishing emails that contained a link to a malicious document disguised to be from the Indian government. The malicious document targets CVE-2017-0199, an old vulnerability in RTF (Rich Text File).

The document contains two hidden macros that drop the Crimson RAT. The malicious macro first creates two directories with the names Edlacar and Uahaiws and then checks the OS type.

Based on the OS type, the macro then picks either the 32-bit or 64-bit version of its RAT payload in .zip format, which is stored in one of two textboxes in UserForm1.

It then drops the .zip payload into the Uahaiws directory and unzips its content (using the UnAldizip function), dropping the RAT payload into the Edlacar directory. Finally, it calls the Shell function to execute the payload.

Once the payload has been launched, Crimson RAT connects to its hardcoded C&C IP addresses and sends collected information about the victim back to the server. This data includes a list of running processes and their IDs as well as machine hostname and its username.

Transparent Tribe (also known as APT36, ProjectM, Mythic Leopard, and TEMP.Lapis) is a Pakistani threat group active since 2012. Transparent Tribe carries out cyberespionage operations with the aim of collecting confidential information from India that supports Pakistani military and diplomatic interests.

Transparent Tribe mainly relies on both spear phishing and watering hole attacks to gain its foothold in victim networks. The phishing email involves either a malicious macro document or an RTF file that exploits vulnerabilities such as CVE-2012-0158 and CVE-2017-0199.

The threat actors used phishing to deliver a remote access Trojan called MSIL/Crimson RAT. In the past, the group also used various RAT malware, such as BreachRAT, PeepyRAT, DarkComet, Luminosity RAT, and njRAT.

APT name	Regions attacked	Operation start
Gorgon Group	Italy, USA, UAE, Pakistan, Germany, Israel	November 2019

In January 2020, new attack attempts by the Gorgon Group targeting Italian retailers were observed.

The initial file is a Microsoft PowerPoint PPA file. It actually is an add-in file designed to add new behavior to the classic PowerPoint presentations, in this case to add a malicious macro. The malicious code within the PPA abuses the Microsoft mshta utility to download a web page from the BlogSpot platform.

The HTML page closely matches the modus operandi of the previous Aggah threat campaign. In this case, the BlogSpot post is named “20sydney new” but it uses the same trick from the past: hiding the JavaScript stager code inside the web page, an ad hoc code snippet that will be interpreted and executed only by the mshta engine.

The first part of this initial implant aims to kill the Word and Excel processes. Immediately after that, the malware downloads other code through leveraging mshta once again, this time from a pastebin snippet.

The author of this paste is no longer HAGGA and moved on to another name, YAKKA3.

The paste was created on November 25, 2019 and it has likely been edited many times in the course the last month. In the past, Aggah frequently changed the content of their pastes to modify malware behaviour and drop many kinds of malware. On some occasions, some of them were suspected to be related to the Gorgon Group.

The encoded script is a piece of VBS script designed to run another Powershell loader. The Powershell script tests Internet connectivity by pinging to google.com and then starts the infection. The script downloads two other pastes. The first one is a PE file, the second one is a custom .NET process injection utility.

The injector component is invoked through its static method [vroombrooomkrooom]::kekedoyouloveme('calc.exe',$f). The only purpose of this component is to inject a payload inside the memory of another process. The injection technique is very basic. In fact, the injection uses the textbook CreateRemoteThread technique, well documented and actively implemented by many actors and malware developers.

As was observed in the past, Aggah used to change its payloads, and this time the delivered malware was not RevengeRAT, rather it was a LokiBot variant.

In December observations of the Aggah campaign, a different payload was detected, AZOrult. Investigating the C&C infrastructure through Azorult-Tracker services, researchers noticed that the AZOrult malware distributed by Aggah in that period was targeting a small number of victims mainly located in the United States, the United Arab Emirates, Pakistan, Germany, and Israel.

Researchers currently believe that Gorgon Group is behind the Aggah campaign. Gorgon Group was discovered in 2017, when it targeted government agencies in the UK, Spain, Russia, and the United States.

APT name	Regions attacked	Operation start
Targeted attack against the UN Office of the High Commissioner for Human Rights	Global	July 2019

The New Humanitarian news agency learned that in 2019 a group of hackers attacked dozens of UN servers, including ones at the UN Office of the High Commissioner for Human Rights. The agency reported the news on January 29, citing an internal UN document.

The UN learned about the attack in late August 2019, but hackers had gained access to the organization's servers at least a month before that. The hackers exploited the Microsoft SharePoint vulnerability CVE-2019-0604.

The breach affected dozens of servers in three separate locations: the UN Office at Vienna, the UN Office at Geneva, and the UN Office of the High Commissioner for Human Rights (OHCHR) headquartered in Geneva. These servers hold a range of data, including personal information about staff.

“Although hackers accessed a self-contained part of our system in July 2019, the development servers they accessed did not hold any sensitive data or confidential information,” reads the official press release of the OHCHR. “The hackers did manage to access our Active User Directory, which contains the user IDs for our staff and devices. However, they did not succeed in accessing passwords. Nor did they gain access to other parts of the system.”

There are suggestions that hackers from North Korea may have been involved in this attack, but this has not been confirmed. The attack on the OHCHR may have been carried out as part of an operation aimed at stealing confidential information, as well as may have been part of a supply chain attack.

APT name	Regions attacked	Operation start
APT41	Hong Kong, Australia, Canada, Denmark, Finland, France, India, Italy, Japan, Malaysia, Mexico, Philippines, Poland, Qatar, Saudi Arabia, Singapore, Sweden, Switzerland, UAE, UK, USA	June 2019

In November 2019, new attacks carried out by the Winnti group were discovered. The ShadowPad launcher was found on several devices at two universities. These were targeted attacks, since the Winnti Trojan and the modular backdoor ShadowPad contained campaign identifiers and C&C URLs with the names of the affected universities.

Researchers say that the threat actors' end goal was to collect and steal data from compromised computers. For instance, The ShadowPad variant discovered on the infected devices features keylogging and screen-capture capabilities, provided to the malware by two of the 17 modules it comes with.

It was also noted that during this campaign, ShadowPad's launcher was replaced with a simpler one that was not obfuscated with VMProtec; it used XOR encryption rather than the typical RC5 key block encryption algorithm.

This campaign was most likely timed to coincide with the civic protests that started in June 2019 triggered by an extradition bill. Even though the bill was withdrawn in October 2019, the protests continued, demanding full democracy and investigation of the Hong Kong police. These protests gathered hundreds of thousands of people in the streets with large support from students of Hong Kong universities, leading to multiple university campus occupations by the protesters.

In January 2020, it was reported that Winnti was behind the attack on the German chemical company Lanxess. It was revealed as early as July 2019 that WinntI had hacked several DAX (key German stock index) companies, including Siemens, BASF and Henkel. Lanxess confirmed that they had been attacked. The malware was discovered "in the second half of last year," which was followed by counter measures. The company declined to comment on the potential data breach.

An investigation into the Winnti malware conducted by BD and NDR journalists revealed that it was likely developed in 2015 to be used at Lanxess. During that time, Winnti also attacked several competitors of Lanxess. This suggests that the attackers spied on the company for years.

The malware ended up in a malware database at the beginning of the year, where experts noticed it. The hackers wrote the name of the hacked company directly into their program, in this case Rheinchemie, a subdivision of Lanxess.

APT41 organized a number of attacks involving exploits for vulnerabilities in Citrix, Cisco, and Zoho devices in various industries worldwide. Specialists at FireEye noted that APT41 carried out one of their broadest campaigns in recent years. Between January 20 and March 11, the specialists observed APT41 attempt to exploit vulnerabilities in Citrix NetScaler/ADC, Cisco routers, and Zoho ManageEngine Desktop Central.

In February 2020, the hackers successfully exploited a Cisco RV320 router at a telecommunications organization. It is unknown what specific exploit was used, but there is a Metasploit module that combines

CVE-2019-1653 and CVE-2019-1652 to enable remote code execution on Cisco RV320 and RV325 small business routers and uses wget to download specified payload.

The threat actors also exploited the CVE-2020-10189 vulnerability in Zoho ManageEngine, which allows for remote code execution without authorization with SYSTEM/superuser rights. The next day after the vulnerability was fixed, the threat actors attacked over a dozen systems and managed to compromise at least five of them. They then installed persistence for a trial-version of Cobalt Strike BEACON loader and employed another backdoor for downloading VMProtected Meterpreter.

APT41 (also known as BARIUM, Winnti, LEAD, Axiom, Group 72, and Double Dragon) is a Chinese state-sponsored threat group that has been active since 2012. The group's espionage campaigns have targeted healthcare, telecommunications and high-tech sectors and have historically involved intellectual property theft. APT41's attacks have targeted the gaming industry, including the manipulation of virtual currencies and attempted deployment of ransomware.

APT name	Regions attacked	Operation start
Kimsuky	South Korea, USA	July 2019

Kimsuky continued its malicious mailouts as part of their Operation Blue Estimate in January and February 2020. Malicious files disguised as double extensions, like PDF documents, are executed in the same way as EXE executables through the actual screen saver (SCR) extension. It creates and loads an image file called "주민등록등본.tif" (which translates as "resident registration copy") included in the internal resource.

The actual resident registration table contains personal information that appears to be related to a former Education Center official. The malicious file was created based on the Korean language. The 103 area contains the image file, and the 104 area contains a 64-bit malicious DLL file.

Since this host file creates and executes a 64-bit DLL file with the name "Hero.dll," an error window may appear when running on a 32-bit operating system.

In February 2020, Kimsuky carried out a malicious mailout in Korean using the COVID-19 topic. This phishing attack targeted international exchange/diplomatic organizations.

The email had an attached DOC called "코로나바이러스 대응.doc" (which translates as "coronavirus response").

If the email recipient launches the malicious document, a malicious macro script in the document is run, and the attacker downloads additional malicious code by exploiting a domestic hosting service previously set. The script connects to a specific server using mshta.

The hackers launched another attack in March 2020. The attack involved a file called "비건 미국무부 부장관 서신 20200302.doc" (which translates as "letter of the US Secretary of State 20200302"). Like in

the previous mailout, when the user clicks on the [Use Content] button that appears in the security warning window, a VBA macro code is executed and attempts to connect to a malicious website (C&C).

Comparison of the C&C address with the attack that involved a COVID-19-related document revealed that both sites used Mirine hosting and the sub-address paths matched exactly.

When “search.hta” code, specified by the attacker, works, another file is consecutively called, and various information about the infected computer is collected and secretly captured.

In addition, a keylogging spy function will be performed, which stores keyboard contents entered by the user along with an additional file download function. It can therefore lead to the leakage of users’ important personal information.

Kimsuky (also known as Velvet Chollima and Thallium) is a hacker group believed to be based in North Korea. The group has been actively attacking entities on the South Korean territory since 2010, but has lately been expanding the geography of their attacks.

APT name	Regions attacked	Operation start
Gamaredon	Ukraine, Japan	November 2019

A new wave of attacks by Gamaredon took place in November 2019. The complex infection chain begins with a weaponized Office document named “f.doc”.

The decoy document is written using the Ukrainian language mixed with many special characters aimed to lure the target to click on it.

The document leverages a common exploit known as template injection and tries to download the second stage from hxxp://win-apu.]ddns.]net/apu.]dot.

This exploit (remote code execution exploit) does not require user interaction; in fact, the Enable macro button is not shown. The downloaded document has the .dot extension, used by Microsoft Office to save templates for different documents with similar formats.

Opening the document reveals that it is empty, but it requires enabling the macro.

The body of the macro can be logically divided into two distinct parts:

- The first one is the setting of the registry key "HKEY_CURRENT_USER\Software\Microsoft\Office\" & Application.Version & _"\Word\Security\" and the declaration of some other variables, such as the dropurl get-icons.]ddns.net.
- The second one is the setting of the persistence mechanism through the writing of the VBS code in the Startup folder with the name “templates.vbs”.

Analysis of the contents of “templates.vbs” reveals that it defines a variable containing a URL. From this URL, it tries to download another stage, then storing it in the C:\Users\admin\AppData\Roaming\ path with a random name. At the end, the “templates.vbs” script will force the machine to reboot.

The dropped sample is an SFX archive, similar to other Gamaredon implants. By simply opening the SFX archive, it is possible to notice two different files named “8957.cmd” and “28847”. The file “28847” is another SFX file, which contains eight files: five of them are legitimate DLLs used by the “6323” executable to interoperate with the OLE format defined and used by Microsoft Office.

Static analysis of the “6323” file revealed that it was written using Microsoft Visual Studio .NET, and was therefore easy to reverse. Before reversing the executable, it was possible to clean it allowing size reduction and junk instruction reduction inside the code.

In March 2020, Trend Micro observed that malicious emails with malware, believed to be by Gamaredon, hit Japan several times. At the moment, it is difficult to determine whether Japan was one of the targets in the attack, or if the hit was accidental.

The emails contained a malicious document that caused "template injection" that read a document template from the Internet; the downloaded document template contained a macro, which led to the execution of VBS. One of the emails had the subject "Coronavirus (2019-nCoV)."

Gamaredon Group (aka Primitive Bear) is a Russian threat group active since at least 2013. The group first borrowed tools for their attacks, but then started using their own malware. Their attacks target governments, law enforcement, and military organizations mostly in Ukraine.

APT name	Regions attacked	Operation start
Goblin Panda	Vietnam	January 2020

In February 2020, security experts discovered a document called “Báo Cáo Sự Kiện Đồng Tâm.doc,” which translates from Vietnamese as “Dong Tam event report.” The document was created on January 10, 2020 at 08:31:00 and purported to contain information about a recent controversy regarding land disputes between the Vietnamese government and the locals of Dong Tam (a rural commune located in Hanoi, Vietnam).

Upon opening the document, CVE-2017-11882 is silently executed in the background. CVE-2017-11882, which was patched by Microsoft in November 2017, is a memory corruption vulnerability that grants the attacker RCE (remote code execution) when the user opens a specially crafted file.

Following exploitation, an embedded object (“wd32PrvSE.wmf”) is dropped to the user’s local temp directory and subsequently executed. “Wd32PrvSE.wmf” then drops three files to the user’s local temp directory: “QcConsole.exe,” “QcLite.dll,” and “stdole.tlb.” While “QcConsole.exe” appears to be a valid and signed file belonging to McAfee, Inc., the other two dropped files (“QcLite.dll” and “stdole.tlb”) have less than benevolent intentions.

“QcConsole.exe” is then executed and loads “QcLite.dll.” “QcLite.dll” will then establish persistence via an autorun registry key named Windows HD Audio Manager, drop a file titled “desktop.ini” to the C:\ProgramData\ directory containing obfuscated data, and load the contents of “stdole.tlb” to memory, and decrypt it.

“Dllhst3g.exe,” a legitimate Windows binary, is then started in a suspended state, injected with the executable data extracted from “stdole.tlb,” and is subsequently resumed. The compromised “dllhst3g.exe” then decodes the contents of the previously dropped “desktop.ini” file, which directs it to the location of “QcConsol.exe,” and “QcConsol.exe” is executed for a second time.

Command & Control communications are then initiated via the secondary “QcConsol.exe” process. Although the specialists were unable to obtain additional C&C communications, the activity observed in relation to the dropped artifacts is very reminiscent of Newcore Remote Access Trojan.

The targeting if the Vietnamese in the attack and the use of Newcore RAT samples similar to previous attacks can suggest that Goblin Panda is behind the attack.

Goblin Panda (also known as Hellsing and Cycledek) is a group that has been active for the better part of the last decade and has historically had information theft and espionage related motives that align with

Chinese interests. Their targets have primarily been defense, energy, and government organizations located in South/Southeast Asia, with emphasis on Vietnamese targeting.

APT name	Regions attacked	Operation start
APT-C-23	Israel	2019

In February 2020, a spokesperson for the Israeli Defence Force (IDF) said that members of the Hamas Palestinian militant group posed as young teenage girls to lure Israeli soldiers into installing malware-infected apps on their phones.

Accounts for six characters used in the recent social engineering campaign were tracked. Soldiers who engaged in conversations were eventually lured towards installing one of three chat apps, named Catch & See, Grixy, and Zatu, where the agents promised to share more photos.

The apps would give the impression that they could not run on soldiers' phones by showing a crash message. The apps would then delete their icons from the soldier's smartphone, tricking the user into thinking the app uninstalled itself.

However, the app would keep running in the background. The malicious apps would then exfiltrate photos, SMS messages, contacts, and more. The apps could also install other malware on the device, track the phone's geolocation in real time, and even take screenshots via the phone's camera.

Israeli cybersecurity firm Check Point attributed the recent malware strains to a group it tracks under the codename APT-C-23. To attack the Israeli military, the hackers used malware viruses written for Android smartphones.

APT-C-23 (also known as FrozenCell, AridViper, Micropsia, and Desert Falcon) represents the interests of the Gaza Strip and targets users in the Middle East, in particular many attacks against Palestine have been observed.

APT name	Regions attacked	Operation start
Kwampirs	USA, Europe, Asia, Middle East	2019

The FBI issued several security alerts this quarter, warning private sector companies about an ongoing hacking campaign targeting software providers. The hackers tried to compromise supply chains by infecting software providers with the Kwampirs Trojan.

The FBI also says the same Trojan was deployed in attacks against companies in the healthcare, energy, and financial sectors. The targeted companies have not been disclosed; only the affected regions have been mentioned: the United States, Europe, Asia, and the Middle East.

"Software supply chain companies are believed to be targeted in order to gain access to the victim's strategic partners and/or customers, including entities supporting Industrial Control Systems (ICS) for global energy generation, transmission, and distribution," the FBI said in a private industry notification.

The FBI says the group gained "broad and sustained access" to targeted healthcare entities. According to the bureau, hacked targets range from major transnational healthcare companies to local hospital organizations. "Infected software supply chain vendors included products used to manage industrial control system (ICS) assets in hospitals."

The FBI credits this to the Kwampirs malware's ability to propagate laterally across networks via the Server Message Block (SMB) protocol or via hidden admin shares.

The Kwampirs Trojan was first described in a Symantec report published in April 2018. The experts then wrote that the hacking group Orangeworm used Kwampirs to attack supply chains and their targets were mainly companies that provided software to the healthcare sector.

Having penetrated into the system, Kwampirs collected basic data about the device and sent it to a remote server. Then using the backdoor on the infected machine, attackers gained access to pieces of sensitive data. If the compromised system was identified as potentially interesting, the data was stolen, as well as the process of "aggressive copying" of the malware hit any available machines and network resources.

According to Symantec, the Orangeworm group has been active since at least 2015, while the FBI says the Kwampirs group has been active since 2016. This could suggest that these are the same group.

APT name	Regions attacked	Operation start
Holy Water: ongoing targeted attack in Asia	Asia	May 2019

In late 2019, security experts discovered a targeted attack involving the watering hole technique. The attack was dubbed Holy Water due to the content of the websites that were used to distribute malware.

This campaign has been active since at least May 2019, and targets an Asian religious and ethnic group. The threat actors at some point managed to compromise a server hosting a dozen websites. These were mainly webpages belonging to religious figures, public bodies, and charities. In the code of these pages, the attackers embedded malicious scripts, which were used for attacks.

When a user visited an infected page, the scripts collected data about them using completely legitimate tools and sent the data to a third-party server to validate the target. If the user was interesting for the attackers, the server sent a command to continue the attack.

Then the user was offered to download an Adobe Flash update. The argument was the insecurity of using an outdated version. If the victim agreed, a Godlike12 backdoor was installed on their computer, instead of an update.

The attackers actively used legitimate services. The backdoor was posted on Github both for profiling victims and storing the malicious code. The backdoor communicated with the management servers through Google Drive.

The backdoor posted an identifier and regularly turned to it to check if commands were received from the operators. It also uploaded the results of command execution. Experts believe the main tasks of the attackers came down to reconnaissance and downloading information from a compromised device.

APT name	Regions attacked	Operation start
WildPressure	Middle East	March 2019

In August 2019, security specialists discovered a malicious campaign distributing a full-fledged C++ Trojan that was dubbed Milum. All the victims were organizations from the Middle East. At least some of them were related to the industrial sector.

Computer systems infected with Milum were first detected by researchers in August 2019. Later, however, they detected traces of infection going as far back as May 31, 2019. Analysis revealed that Milum was compiled two months prior — in March 2019.

For their campaign infrastructure, the operators used rented OVH and Netzbetrieb virtual private servers (VPS) and a domain registered with the Domains by Proxy anonymization service.

The malware uses the JSON format for configuration data and as a C&C communication protocol over HTTP as well. Inside the encrypted communications within the HTTP POST requests, several interesting fields were found. One of them shows the malware version – 1.0.1. A version number like this indicates an early stage of development. Other fields suggest the existence of, at the very least, plans for non-C++ versions.

The only encryption implemented is the RC4 algorithm with different 64-byte keys for different victims.

According to security analysts, Milum is made up of relatively new code, with no intersections or similarities to any other APT operation. In particular, the malware is able to perform the following functions: download and execute the commands of its operator, collect various information from the target device and send it to the C&C server, and update to a newer version.

APT name	Regions attacked	Operation start
APT37	South Korea	March 2020

Security experts detected a new campaign conducted by the state-sponsored APT37 group in early March 2020. The campaign was named Operation Spy Cloud.

The spear-phishing email used in the attack contained a malicious link, which tricks users to click to download a file with a malicious MS Word DOC document attachment.

Based on collected samples, the campaign's decoy documents used the file formats DOC, XLS, and HWP, the Korean government standard word processor format, targeting users in South Korea.

The analysis result of the malicious DOC Word file used for the attack reveals that the shellcode is combined with an obfuscated malicious VBA macro.

During the execution of shellcode, it connects to Google Drive, set as the C&C server, executes the EXE malicious module, and attempts to leak computer information to pCloud.

APT37 (also known as Group123, Reaper, ScarCruft, Geumseong121, and Red Eyes) is a North Korean cyberespionage group active since at least 2012. The group primarily targets South Korea, but also Japan, Vietnam, Russia, Nepal, China, India, Romania, Kuwait, and other regions.

APT name	Regions attacked	Operation start
BlackTech	-	2018

At the beginning of 2020, JpCERT reported that in addition to the known Trojans TSCookie, PLEAD, and IconDown for Windows, the BlackTech group developed variants of TSCookie and PLEAD that infect Linux.

The JpCERT article describes differences between TSCookie for Windows and Linux and notes that while they are mostly the same in terms of the code, the Linux version operates differently with the following characteristics:

- Less configuration
- Supports custom communication protocol only
- Several functions available by default

TSCookie for Windows has 17 sets of configurations within the 0xB78 data size. On the other hand, it is reduced to 5 in the Linux version, and the configuration on proxy communication and others have been excluded.

In the Windows version, the configuration is RC4-encrypted and hardcoded in the malware. For the Linux version, however, information such as C&C server is copied as plain text into a dedicated area in memory and then RC4-encrypted.

While TSCookie for Windows supports several communication protocols (HTTP, HTTPS, and custom protocol), the Linux version only supports its custom protocol. The payload itself is RC4-encrypted in both versions, and the format of the data as well as the commands received in response remain mostly the same.

TSCookie for Windows downloads modules and operates accordingly. The Linux version has the following functions by default, so it conducts malicious activities without downloading extra modules.

- Execute arbitrary shell command
- Operate files (list, delete, move)
- Upload/Download files

BlackTech is a cyberespionage group operating against targets in East Asia, particularly Taiwan, and occasionally Japan and Hong Kong. Based on the mutexes and domain names of some of their C&C servers, BlackTech's campaigns are likely designed to steal their targets' technology. Three main campaigns are linked to the group: PLEAD, Shrouded Crossbow, and Waterbear.

APT name	Regions attacked	Operation start
Tonto Team	Russia, Japan, South Korea	2010

According to a report by Cisco Talos, the Chinese threat group Tonto Team continues to improve and deploy the decade-old Remote Access Trojan (RAT) Bisonal, which is still used in attacks against Russian, Japanese, and South Korean targets.

It is believed that the campaigns had very specific targets which would suggest the group's end goal was more around operational intelligence gathering and espionage.

The first stage of the attack chain is usually a spear-phishing email containing a malicious document. The 2009 attacks involved malicious documents related to national research, the military, and the South Korean government, as well as Russian companies. More recently, Talos identified a Russian RTF document designed to drop the file "winhelp.wll" containing Bisonal, alongside a variety of South Korean documents using similar RTF exploits to drop the malware. The Russian example relates to research, while the South Korean ones relate to the country's government.

The Tonto Team APT is believed to be linked to the Chinese military, since, according to researchers, it is related to the Shenyang Military Region Technical Reconnaissance Bureau. The hackers' focus is on espionage against governments, media outlets, and the military, primarily in Russia, Japan, and South Korea.

APT name	Regions attacked	Operation start
Gaza Cybergang	Saudi Arabia, USA, UAE, UK, Djibouti, Spain	October 2019

Between October 2019 through the beginning of December 2019, security researchers observed multiple instances of phishing attacks likely related to a threat group known as Molerats (also known as Gaza Hackers Team and Gaza Cybergang) targeting eight organizations in six different countries in the government, telecommunications, insurance and retail industries, of which the latter two were quite peculiar. The targeting of insurance and retail organizations is peculiar as it does not fit with this threat group's prior target set. The email subject and attachment file names used in the attacks on these seemingly atypical targets were similar in theme to ones involved in attacks against government organizations.

All of the attacks involved spear-phishing emails delivering malicious documents that required the recipient to carry out certain actions. The social engineering techniques included lure images attempting to trick the user into enabling content to run a macro and even document contents that threaten to release compromising pictures to the media to coerce the user into clicking a link to download a malicious payload. In the majority of these attacks, the payload was a backdoor called Spark, which allows threat actors to open applications and run command line commands on the compromised system.

Gaza Cybergang (Molerats) has been active since 2012 and has been mainly targeting government agencies in the MENA region. The attackers use phishing emails, paste sites hosting malware stages, social engineering methods, and different RATs. The group's goal is to collect intelligence data.

APT name	Regions attacked	Operation start
Nuo Chong Lions	Middle East	September 2013

February 2020 saw the discovery of a wave of attacks that had been ongoing for several years, as well as the group behind them, which remained undetected all that time, Nuo Chong Lions (also known as SilencerLion).

Since the intervention of Yemen called Operation Restoring Hope, which began on April 22, 2015, in the months after the end of the 2018 World Cup, the group continued targeting Arab users, Shiites and commentators. After the attack, security specialists found that many social media accounts that had been attacked became "silent accounts."

Having a virtual team composed of a large number of robots and hundreds of thousands of young people employed to spread false information and pro-government propaganda, Nuo Chong Lions focused for a long time on surveillance attacks, making domestic and foreign critics remain silent and used expensive spyware.

The Nuo Chong Lions organization may have trained (bribed) two Twitter employees to try to access private information of dissidents and radicals, including phone numbers and IP addresses. On November 11, 2015, Twitter issued a security notice to dozens of users whose accounts had been accessed by one of the former Twitter employees.

On September 20, 2019, Twitter issued a new disclosure notice, announcing the permanent suspension of a Twitter account called Saud al-Qahtani. Saud al-Qahtani is a former advisor to the Crown Prince of Saudi Arabia; he requested the Israeli company NSO Group to spy on activists and journalists who were critical of Riyadh.

In addition, the hackers manipulated YouTube and Facebook.

In their attacks, the hackers employed the watering hole technique and spear phishing. Nuo Chong Lions used four mobile RATs in its historical attack activities, including an open-source RAT (AndroRat) and three commercial RATs (SandroRat, SpyNote, and MobiHok).

Researchers provided hashes and compilation dates of the malicious programs, which revealed that the group started to be active in 2013 and operated up until August 2018. There is a suggestion, however, that the organization is likely to become active again after recent changes in its leadership.

Data leaks

- In late March, the data of 538 million users of the Chinese social networking service Weibo was put up for sale on an underground forum. The data included users' full names, usernames, gender, and location, and phone numbers for 172 million users.
  The seller claims they breached Weibo in mid-2019 and obtained a dump of the company's user database.
  The incident is currently being investigated by law enforcement agencies. However, Weibo denies that a data breach took place.
- Whisper, an application intended for anonymous exchange of posts and messages, put user data at risk. A 75-TB user database was publicly available. It contained about 900 million records dated 2012–2020, i.e. from the launch of the service up until now. As it turned out, Whisper stored data since 2012 hardly deleting anything. The database did not contain users' names, but it included nicknames, stated age, ethnicity, gender, city, country, IP address, time zone, location data, and group memberships.
  The vulnerability has now been fixed.
- In March, an open database (AWS S3 bucket) of Merchant Cash Advance (MCA), an app for short-term loans, was exposed online. The 425-GB database contained about 500,000 documents of various financial companies.
- In February 2020, security researchers reported about a data breach affecting over 10.6 million people who had stayed at MGM Resorts hotels. In addition to information about regular tourists and travelers, the data leak includes personal data and contact details of celebrities, tech CEOs, reporters, government officials, and employees at some of the world's largest tech companies. MGM Resorts later confirmed that in the summer of 2019 they discovered unauthorized access to a cloud server that contained a limited amount of information for certain previous guests of MGM Resorts. The company said that no financial, payment card or password data was involved in the matter.
- The developers of Blisk, a Chromium-based browser that supports advanced developer tools, caused a data leak by leaving an Elasticsearch server exposed online. The database contained about 2.9 million records. The data appeared to be log entries for actions developers were taking inside the browser, such as registering profiles or inviting friends. The data leak included email addresses and user-agent strings.
- In late March, 42 million accounts (IDs and phone numbers) of Iranian Telegram users were leaked online. The incident occurred because of an unofficial (third-party) version of the app, which left the database exposed online without a password.
- In March, an unprotected database that could belong to an information security company was discovered. The SSL certificate and reverse DNS records point to the UK firm Keepnet Labs. The data leak is characterised by the compromise of a storage space with records from a number of other data leaks that took place between 2012 and 2019. The discovered Elascticsearch server contained two databases. The first one included over 5 billion records, the second one was much smaller, containing about 15 million records, but it was updated in real time.
- Data leaks occurred at US medical companies Health Share of Oregon (654,000 records), Rady's Children's Hospital, and Munson Healthcare (the exact number of compromised records is unknown). Both cases affected personal data such as names, contact details, SSNs, and other patient data.
- An unprotected Amazon S3 bucket storage space of Tetrad, a marketing company, contained over 120 million records. The vulnerability was detected by UpGuard specialists.
- A Microsoft database was found exposed on the web. It contained 250 million Microsoft customer service records for 2005–2019. The database included email addresses, IP addresses, geolocation data, internal notes, and so on.

- In February, the gaming website AnimeGame suffered a data breach. The leak contained 1.4 million records: email addresses, usernames, and password hashes. The data was later published on underground forums.